

ICT2204

Ethical Hacking

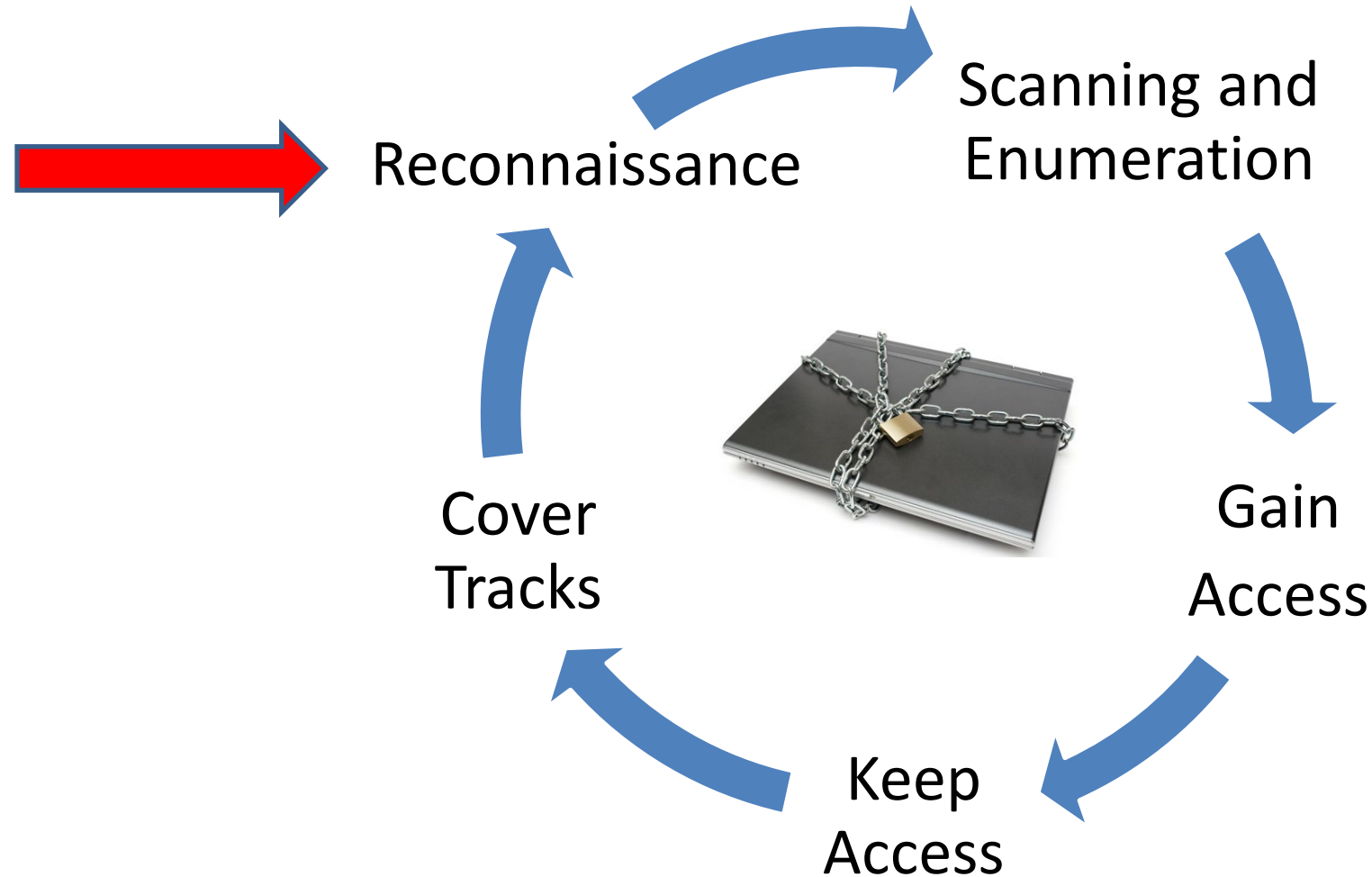


Reconnaissance
A/Prof Guo Huaqun (Linda)

Acknowledgement

- This set of slides is based on a version from Dr. Raymond Chan (Some slides developed by A/Prof Peter Loh) and then updated and added some slides by A/Prof. Guo Huaqun (Linda).

(Ethical) Hacking Process Review



Phases can be repeated till target is reached – Lateral Movement

What is Reconnaissance?



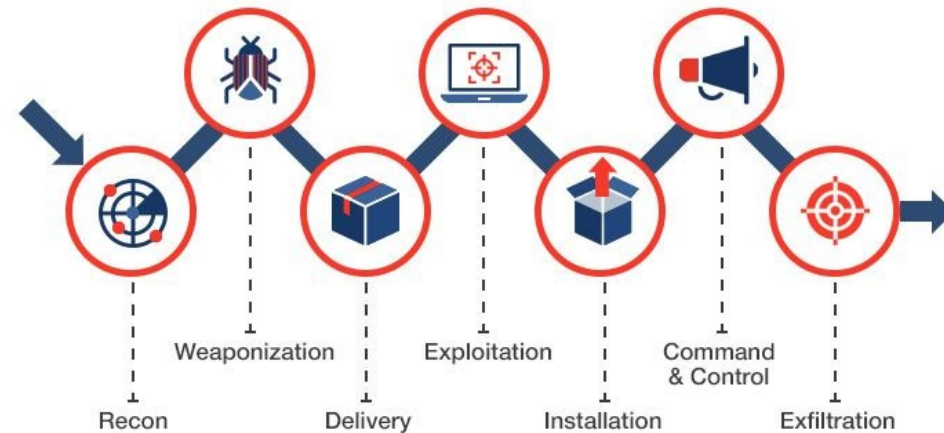
Which house contains the valuables you are looking for?

How am I getting in?



Why Do Reconnaissance? – 1

- **Objective -> Damage reputation of Company X**
- **How do you even start?**
 - What is the most publicized reputable asset?
 - Where is it located? Is the location found, exact?
 - What technologies are used to host it?
- **If you cannot answer these questions, how will you attack?**



- Gain as **much information** about target before attacking - profiling
- Can determine attack(s) techniques and tools to use
- How best to launch attack(s) successfully without raising alerts?

Why Do Reconnaissance? - 2

- If you know the enemy and know yourself, you need not fear the result of a hundred battles.
- If you know yourself but not the enemy, for every victory gained you will also suffer a defeat.
- If you know neither the enemy nor yourself, you will succumb in every battle.

—Sun Tzu, The Art of War

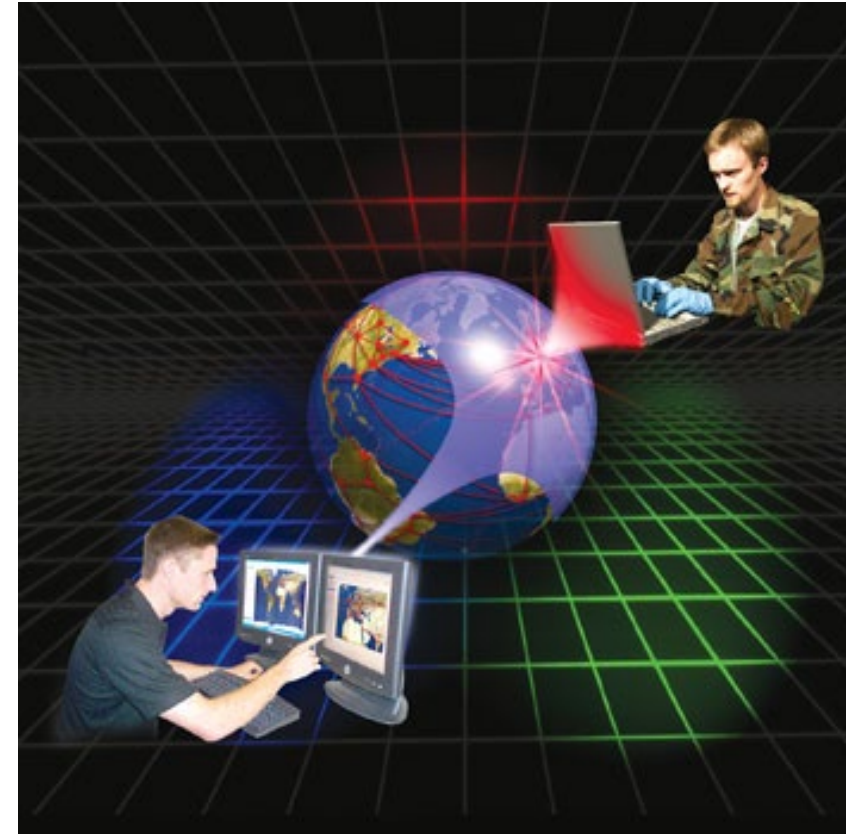
- To be an effective security pentester, you need to know a system's vulnerabilities and understand an attacker's mindset.

— ICT 2212 Ethical Hacking



Introduction to Reconnaissance

- Find out all you can about target:
 - Location, neighbours
 - Technologies
 - People
 - Scope – overlaps with next phase
- Reconnaissance techniques and tools:
 - Whois databases
 - Netcraft
 - Shoulder Surfing
 - Dumpster Diving
 - Social Engineering
 - Google Hacking
 - Doxing



Reconnaissance Techniques and Tools

WHOIS DATABASES

Whois Databases

- Web-based Info Harvesting Technique
- Evolved from Unix OS
- Can be found in other OSs and hacking toolkits:
 - Download at <https://docs.microsoft.com/en-us/sysinternals/downloads/whois>
- Output contains:
 - Domain name
 - Registrant (domain owner)
 - Name servers for domain name in question
 - Names and contact info of admin, technical staff etc.
- Some links for Whois reconnaissance
 - <https://www.whois.com/whois/>
 - <https://who.is/>
 - <https://whois.domaintools.com/>

Whois Online – Example

WHOIS Lookup

Search domain name registration records

Q SEARCH

Examples: facebook.com, google.co.in, bbc.co.uk, ebay.ca

- <https://www.whois.com/whois/>
- The WHOIS service is not a single, centrally-operated database; the data is managed by independent entities known as **registrar** and **registry**
- Any entity that wants to become a registrar must earn Internet Corp for Assigned Names and Numbers (ICANN) accreditation; Similarly, registries are under contract with ICANN to operate a generic top level domain, such as .COM, .ORG
- A Domain Name Registry, like Verisign, is an organisation that holds the database of all registered domain names in a certain Top Level Domain (TLD) such as .com

Whois Online – Example 1 Output

Registrar: IP MIRROR PTE LTD

Domain Name: OCBC.COM.SG
Creation Date: 29-Aug-1996 00:00:00
Modified Date: 24-Jul-2018 22:43:22
Expiration Date: 29-Aug-2019 00:00:00
Domain Status: OK
Domain Status: CLIENT TRANSFER PROHIBITED
Domain Status: **VerifiedID@SG**-Not Required

Registrant:

Name: OVERSEA-CHINESE BANKING CORPORATION LIMITED (SGNIC-ORGOV337833)

Administrative Contact:

Name: OVERSEA-CHINESE BANKING CORPORATION LIMITED (SGNIC-ORGOV337833)

Technical Contact:

Name: OVERSEA-CHINESE BANKING CORPORATION LIMITED (SGNIC-ORGOV337833)
Email: **corpconns@ocbc.com**

Whois Online – Example 2 Output

WHAT INFO IS USEFUL?

<https://www.whois.com/whois/>

ADMINISTRATIVE CONTACT

Name: Alan Paller
Organization: The SANS Institute
Street: 8120 Woodmont Avenue
City: Bethesda
State: MD
Postal Code: 20814
Country: US
Phone: +1.3019510102
Fax: +1.3019510104
Email: noc@sans.org

Domain:
gla.ac.uk

Registered For:
University of Glasgow

Domain Owner:
University of Glasgow

Registered By:
University of Glasgow

Servers:
dns0.gla.ac.uk 130.209.16.6
dns1.gla.ac.uk 130.209.4.16
dns2.gla.ac.uk 130.209.4.18

Registrant Contact:
Iain Bryson

Registrant Address:
Computing Service
University of Glasgow
Glasgow
G12 8QQ
United Kingdom
+44 141 330 4892 (Phone)
+44 141 330 4850 (FAX)
i.bryson@compserv.gla.ac.uk

Whois Online – Example 3 Output

The **registrar** will check if domain name is available and create a **WHOIS** record with the domain name **registrant's** information

The **registrant** is the legal owner of the domain

Social engineering or phishing target

Name servers help map domain names to IP addresses

Registrar: SINGNET PTE LTD

Domain Name: NUS.EDU.SG
 Creation Date: 03-Sep-1996 00:00:00
 Modified Date: 28-Aug-2017 09:04:11
 Expiration Date: 03-Sep-2018 00:00:00
 Domain Status: OK
 Domain Status: VerifiedID@SG-Not Required

Registrant:

Name: NATIONAL UNIVERSITY OF SINGAPORE (SGNIC-ORGNA66731)

Administrative Contact:

Name: NATIONAL UNIVERSITY OF SINGAPORE (SGNIC-ORGNA66731)

Technical Contact:

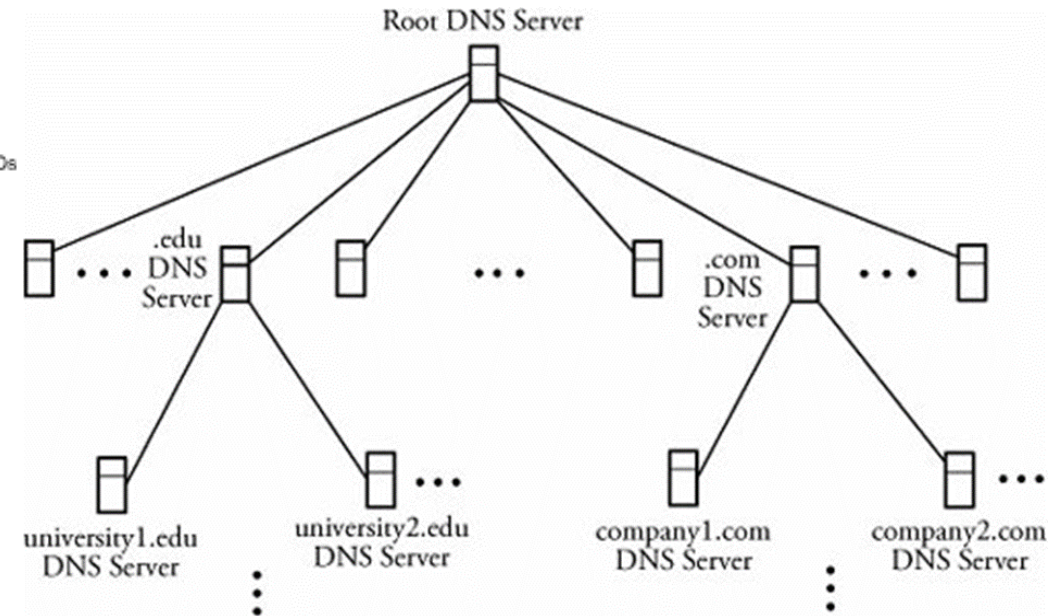
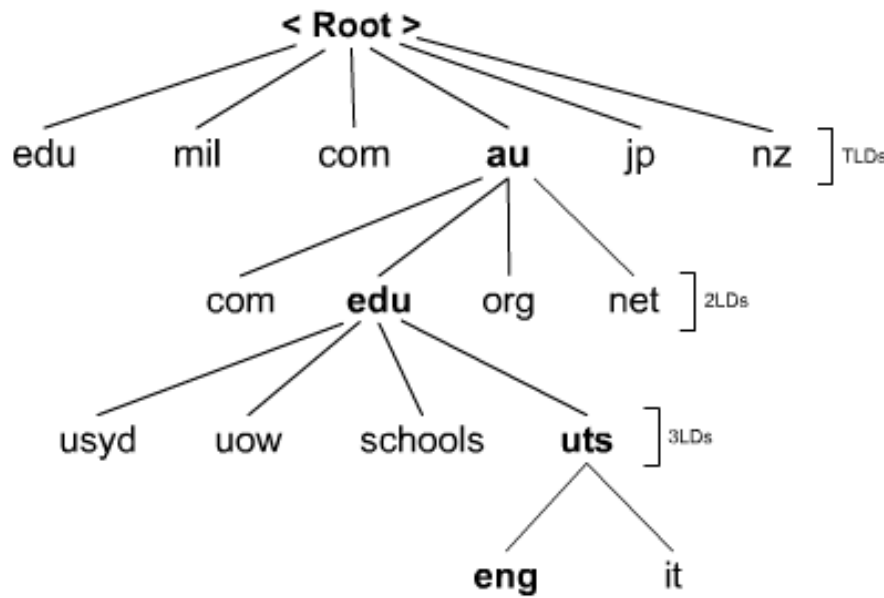
Name: NETWORK GROUP (SGNIC-PERNE66733)
 Email: ccenet@nus.edu.sg

Name Servers:

NS1.NUS.EDU.SG (137.132.123.4)
 NS2.NUS.EDU.SG (137.132.5.2)
 DNSSEC1.SINGNET.COM.SG (165.21.83.11)
 DNSSEC2.SINGNET.COM.SG (165.21.83.11)
 DNSSEC3.SINGNET.COM.SG (165.21.100.11)

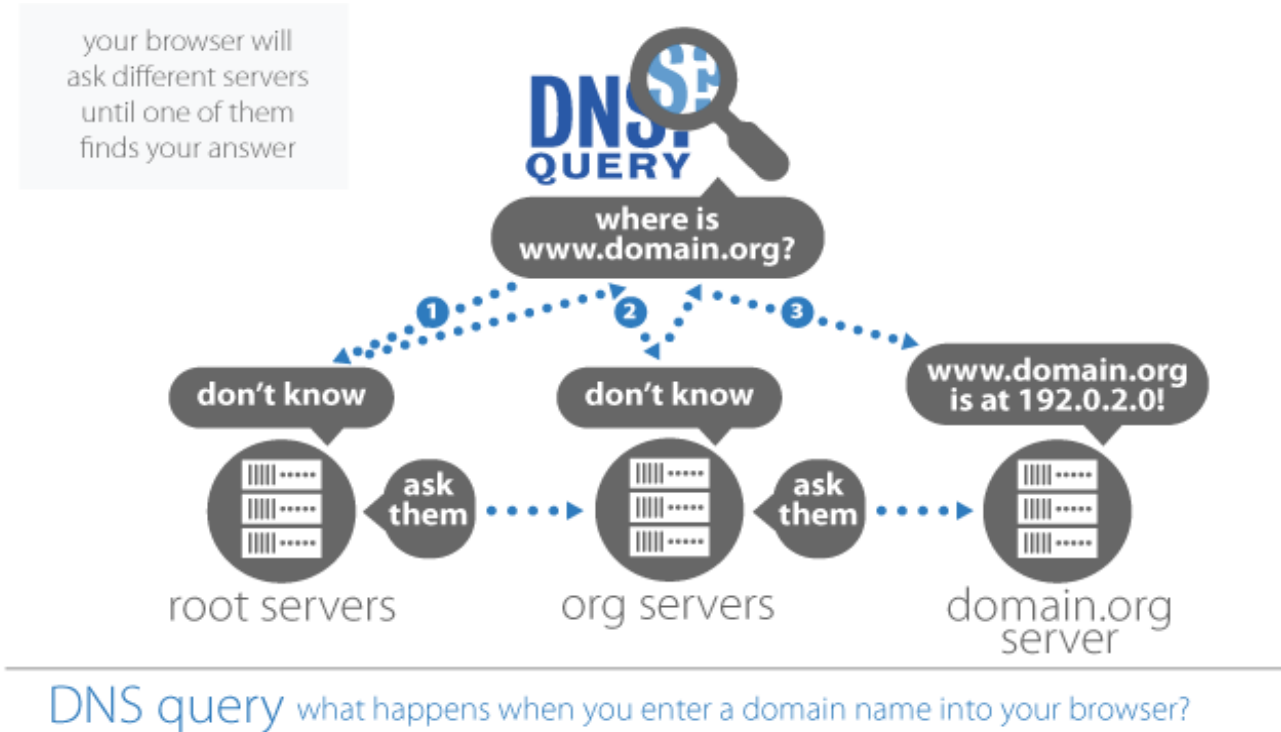
DNSSEC helps prevent DNS spoofing cache poisoning & MITM

How Does Whois Work? - Domains



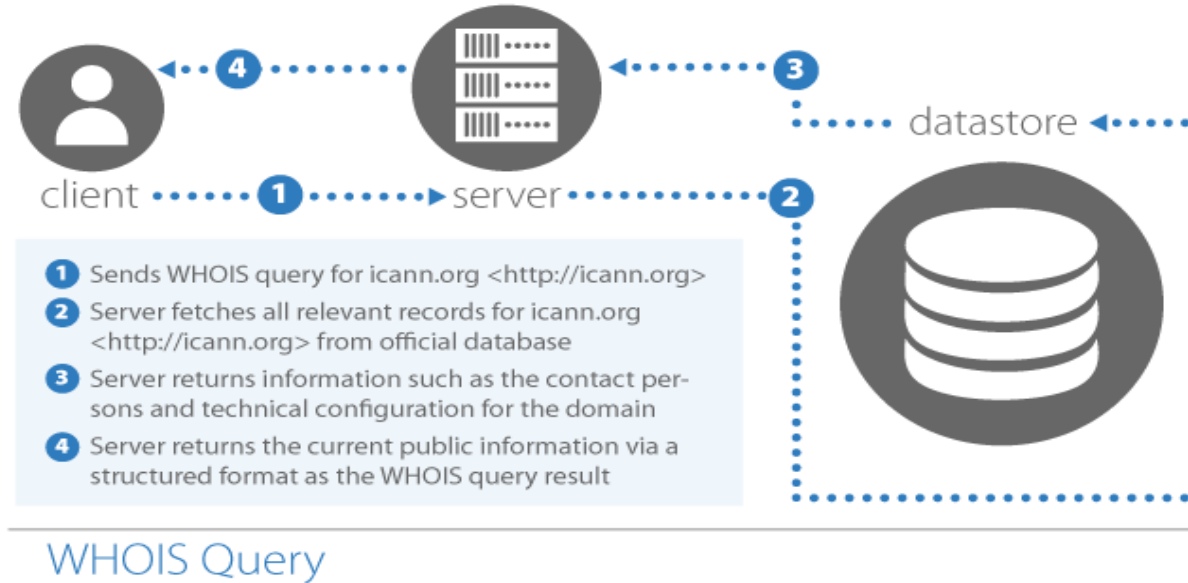
- A domain is a logical region of the Internet. Domain names consist of one or several parts separated by periods, eg. “singaporetech.edu.sg.”
- Top-Level Domain (TLD) name – rightmost portion of the domain name, eg. “.sg”
- A Second-Level Domain (SLD) – next portion of a domain name (right to left), eg. “.org”. Some domain names may belong to different level domains, e.g. “.edu”
- All computers that share the rightmost portion of the name are in the same domain, for example: “ibm.com”, “Microsoft.com”

How Does Whois Work? – DNS Query



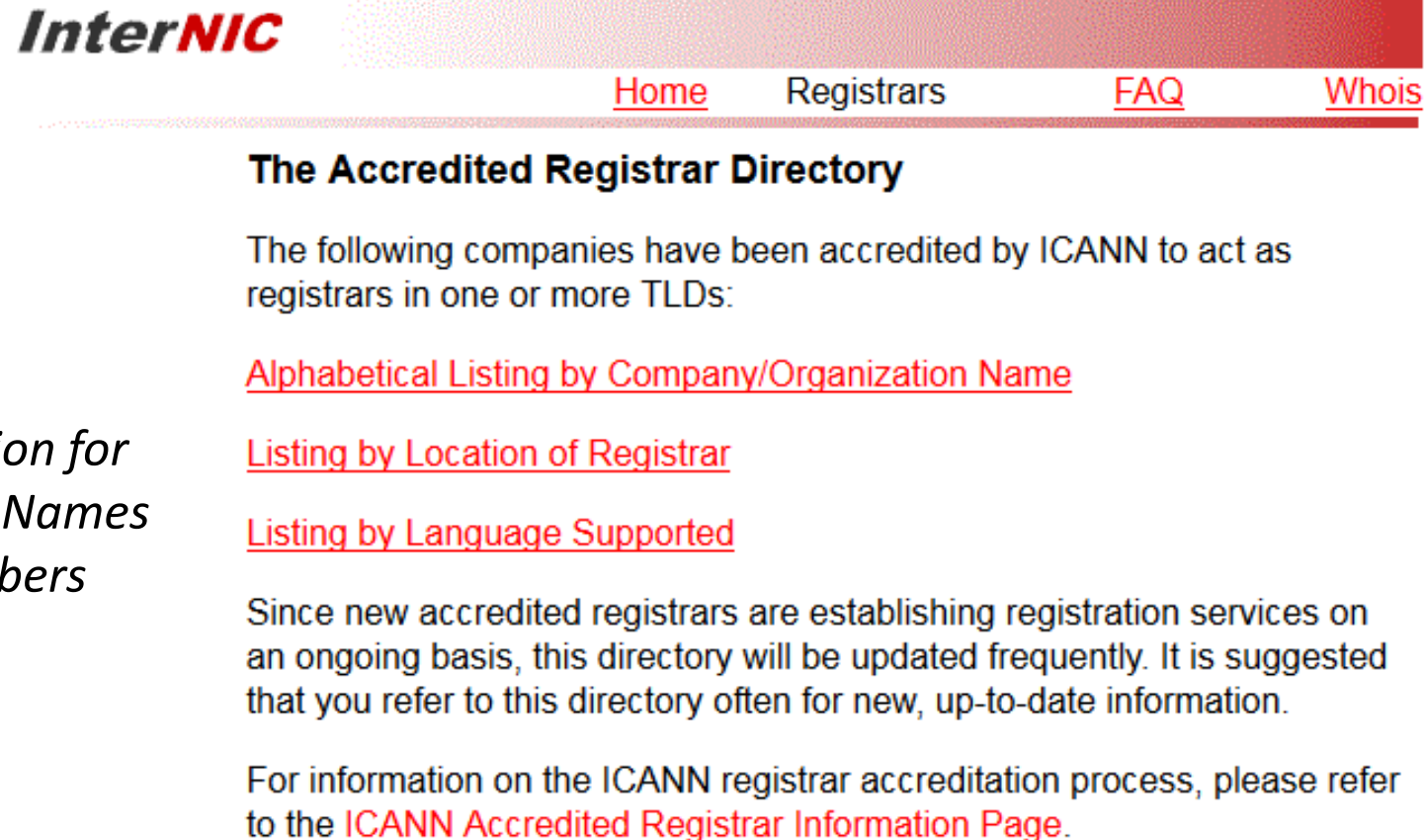
- DNS – Domain Name System
- Each computer is assigned a unique IP address, a hostname is an alias for this IP, e.g. "SIT-NB-X220-456"
- Whenever you type a domain name into your browser, name servers provide the IP address of the domain web server to your browser

How Does Whois Work? – Whois Query



- The **WHOIS** is a query/response protocol that is used to query servers, operated by Regional Internet Registries, which hold information about internet resources such as domain names and IP address allocations
- A WHOIS query needs to contact server of domain name registrar
- The **WHOIS** protocol is a TCP-based protocol designed to work on the port 43

ICANN-Accredited Registrars



InterNIC

[Home](#)[Registrars](#)[FAQ](#)[Whois](#)

The Accredited Registrar Directory

The following companies have been accredited by ICANN to act as registrars in one or more TLDs:

[Alphabetical Listing by Company/Organization Name](#)

[Listing by Location of Registrar](#)

[Listing by Language Supported](#)

Since new accredited registrars are establishing registration services on an ongoing basis, this directory will be updated frequently. It is suggested that you refer to this directory often for new, up-to-date information.

For information on the ICANN registrar accreditation process, please refer to the [ICANN Accredited Registrar Information Page](#).

*Internet
Corporation for
Assigned Names
and Numbers*

- InterNIC (Internet Network Information Center)
- A **registrar** offers domain name registration services
- List of current ICANN-accredited registrars:
<https://www.internic.net/regist.html>
- ICANN is the authoritative registry for all Top-Level Domain (TLD) registries

ICANN Registries

TLD	Introduced	WHOIS Directory Service	Contact
.abb	2015	https://whois.nic.abb/	Affolterstrasse 44 Zurich 8050 CH +41 58 585 56 34 ngtld-abb@cscinfo.com http://abb.com
.ABBOTT	2014	https://whois.nic.ABBOTT/	Abbott Laboratories, Inc. 100 Abbott Park Road Abbott Park IL, 60064 US Tel: +1 224 667 6100 http://www.nic.abbott

**HAS
ICANN
BEEN
HACKED?**

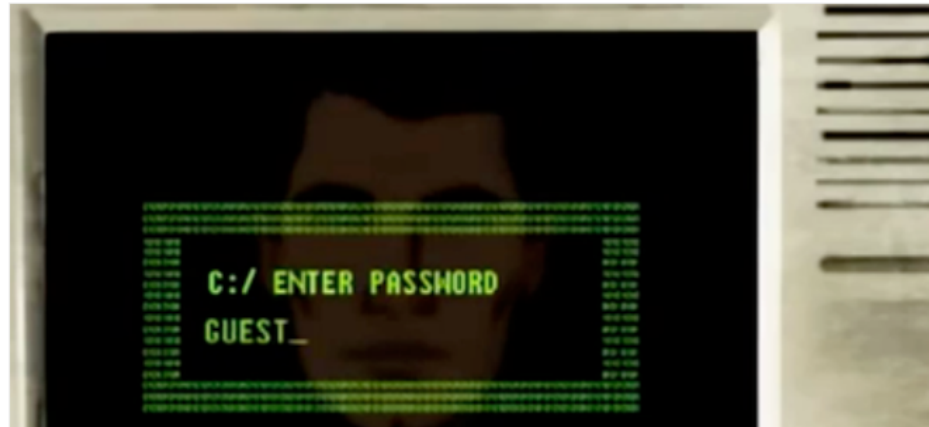
- Right-most label in a domain name (e.g. .com in www.google.com) is referred to as its **top-level domain** (TLD)
- An ICANN Registry is an organisation that holds the database of all registered domain names in a certain Top Level Domain (TLD) such as .com
- Registry Listing: <https://www.icann.org/en/contracted-parties/registry-operators/resources/listings>

Security

ICANN HACKED: Intruders poke around global DNS innards

Spear-phishing attack timing couldn't be worse for domain name overseer

By Kieren McCarthy in San Francisco 17 Dec 2014 at 17:57 53  SHARE ▼



What would happen if ICANN got hacked?

- Access to all the zone files of the world's generic top-level domains
- TLD Zone Files contain info needed to resolve domain names to Internet Protocol (IP) numbers

Global Internet Authority – ICANN Hacked Again!

📅 August 06, 2015 👤 Swati Khandelwal



- *Unauthorised person gained access to **usernames, email addresses, and encrypted passwords** for profile accounts on *ICANN.org* public website*
- *It was believed that leaked information includes harmless information such as user preferences, public biographies, interests, newsletters, and subscriptions*

ICANN HACKED - 3

- **Tampering with the DNS Root Zone**
 - Widespread DNS redirection (to malicious or fake versions of websites)
 - Loss of trust in DNS lookups
 - Potential for massive phishing attacks
 - E.g., type in your bank's URL and go to a hacker's site that looks identical
- **Loss or Corruption of WHOIS Data**
 - Fake or altered domain ownership records
 - Disruption in domain disputes or transfers
 - Difficulties verifying legitimate domain owners
- **Compromise of Registrar Systems and access to the registrar accreditation system is gained**
 - Fraudulent domain registrars could be created.
 - Unauthorized domain purchases or hijackings could occur.
 - Legitimate domain registrars might be de-accredited or blocked.

Reconnaissance Techniques and Tools

DNS DATA VIEW, NSLOOKUP, DIG

DNS Data View – Extract DNS records

Record Type	Host Name	IP Address	More Data	Section
NS	dnssec1.singnet.com.sg	165.21.83.11		Answer
NS	dnssec3.singnet.com.sg	165.21.100.11		Answer
NS	ns.sutd.edu.sg	202.94.70.254		Answer
NS	secdns2.starhub.net.sg	203.116.148.36		Answer
MX	sutd-edu-sg.mail.eo.out...	65.55.88.234	Preference: 0	Answer
MX	mail.global.frontbridge....	207.46.163.138	Preference: 5	Answer
A	sutd.edu.sg	202.94.70.56		Answer
CNAME			Error 9501: No records found for given DNS query.	
SOA	ns.sutd.edu.sg	202.94.70.254	Admin: hostmaster.sutd.edu.sg, Default TTL: 3600, Expire: 1209...	Answer
TEXT			v=spf1 ip4:103.24.77.20 ip4:202.94.70.20 include:spf.protection....	Answer
TEXT			google-site-verification=gfLXPK599jxeRZWmFthrpB1waWNe...	Answer

- Retrieve DNS records of specified domains – (MX, NS, A, SOA)
- DNS records are basically mapping files that tell DNS server which IP address each domain is associated with, and how to handle requests sent to each domain
- MX – Mail Exchange record (list of mail exchange servers, preference - priority)
- NS – Name Server record (list of name servers)
- A – Address Mapping record (gives IP address of domain)
- CNAME – used to create aliases for domain names
- SOA – Start of Authority record (zone admin info)

Kali Linux nslookup – Extract DNS records

```
root@kali2204: ~  
File Edit View Search Terminal Help  
root@kali2204:~# nslookup nus.edu.sg  
Server:      172.21.2.8  
Address:     172.21.2.8#53  
  
Non-authoritative answer:  
Name:   nus.edu.sg  
Address: 137.132.21.27  
  
root@kali2204:~# nslookup ntu.edu.sg  
Server:      172.21.2.8  
Address:     172.21.2.8#53  
  
Non-authoritative answer:  
Name:   ntu.edu.sg  
Address: 155.69.7.173  
  
root@kali2204:~#
```

```
nslookup -type=mx microsoft.com  
nslookup -type=soa microsoft.com
```

```
root@kali:~# dig sutd.edu.sg  
  
; <<>> DiG 9.10.6-Debian <<>> sutd.edu.sg  
;; global options: +cmd  
;; Got answer:  
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 26164  
;; flags: qr rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1  
  
;; OPT PSEUDOSECTION:  
; EDNS: version: 0, flags:; MBZ: 0x0005, udp: 4096  
;; QUESTION SECTION:  
;sutd.edu.sg.                IN      A  
  
;; ANSWER SECTION:  
sutd.edu.sg.                5       IN      A      202.94.70.56  
  
;; Query time: 17 msec  
;; SERVER: 192.168.174.2#53(192.168.174.2)  
;; WHEN: Mon Aug 27 08:08:37 EDT 2018  
;; MSG SIZE rcvd: 56  
  
root@kali:~#
```

- nslookup – name server lookup; used to query internet name servers interactively
- It can translate a domain name to an IP address or vice versa (also try dig)

Reconnaissance Techniques and Tools

NETCRAFT AND BUILTWITH

Netcraft

- Provides internet security and data mining services
- <https://searchdns.netcraft.com/>, <https://www.netcraft.com/>
- Can be used to footprint a website
- Output contains:
 - Domain name owner (registrant)
 - E-mail addresses
 - Name servers for domain name in question
 - Names and contact info of admin, technical staff etc.
 - Web server technologies ← similar to whois, but provide more information



- Web-based reconnaissance tool
- Located at: <https://builtwith.com/>
- Find out what technologies a website is built with
- Outputs include:
 - Analytics and Tracking
 - Frameworks
 - Content Delivery Network
 - JavaScript Libraries and Functions
 - Email Hosting Providers
 - SSL Certificates
 - Web Hosting Providers
 - Web Servers

Web Hosting Providers

Global Trends

 Amazon

[Amazon Usage Statistics](#) · [Download List of All Websites using Amazon](#)

This site is hosted on Amazon AWS EC2 Infrastructure.

Cloud Hosting Cloud PaaS

 Amazon Singapore Region

[Amazon Singapore Region Usage Statistics](#) · [Download List of All Websites using Amazon Singapore Region](#)

Amazon Hosted EC2 Instances in Singapore

 Incapsula

[Incapsula Usage Statistics](#) · [Download List of All Websites using Incapsula](#)

Security performance and CDN optimizer tools

US hosting

 Sharepoint Online

[Sharepoint Online Usage Statistics](#) · [Download List of All Websites using Sharepoint Online](#)

SharePoint Online lets you create sites to share documents and information with colleagues, and customers.

Canadian hosting

Reconnaissance - Purpose

- Ethical hackers do comprehensive reconnaissance
- Many script kiddies skip this step
- **DNS Data View**, **nslookup** and **dig** are OS-specific reconnaissance tools
- **Whois**, **Netcraft** and **Builtwith** are useful browser-based reconnaissance tools
- Tools provide useful preliminary reconnaissance info on target
- Serve as useful inputs for subsequent social engineering as well as scanning and enumeration

Is the info enough? – What else can we do?

Other Reconnaissance Techniques

- Sometimes the most effective technique is the simplest one (may not even require a computer):
 - Shoulder Surfing }
 - Dumpster Diving } **No Tech Hacking**
 - Social Engineering }



Shoulder Surfing

- Physical method of gaining private information based on stealth:
 - Observational attack – with or without technology support
 - Used anywhere - offices, airport lounges, hotel lobbies
 - Many people are completely unaware of being spied upon
 - Information you can gather:
 - ❑ Private email sessions, classified documents, corporate secrets, usernames or passwords
 - ❑ Even classified documents over the shoulder of an unwary government employee
 - ❑ Credit card numbers and passwords over phone



Automated Shoulder Surfing



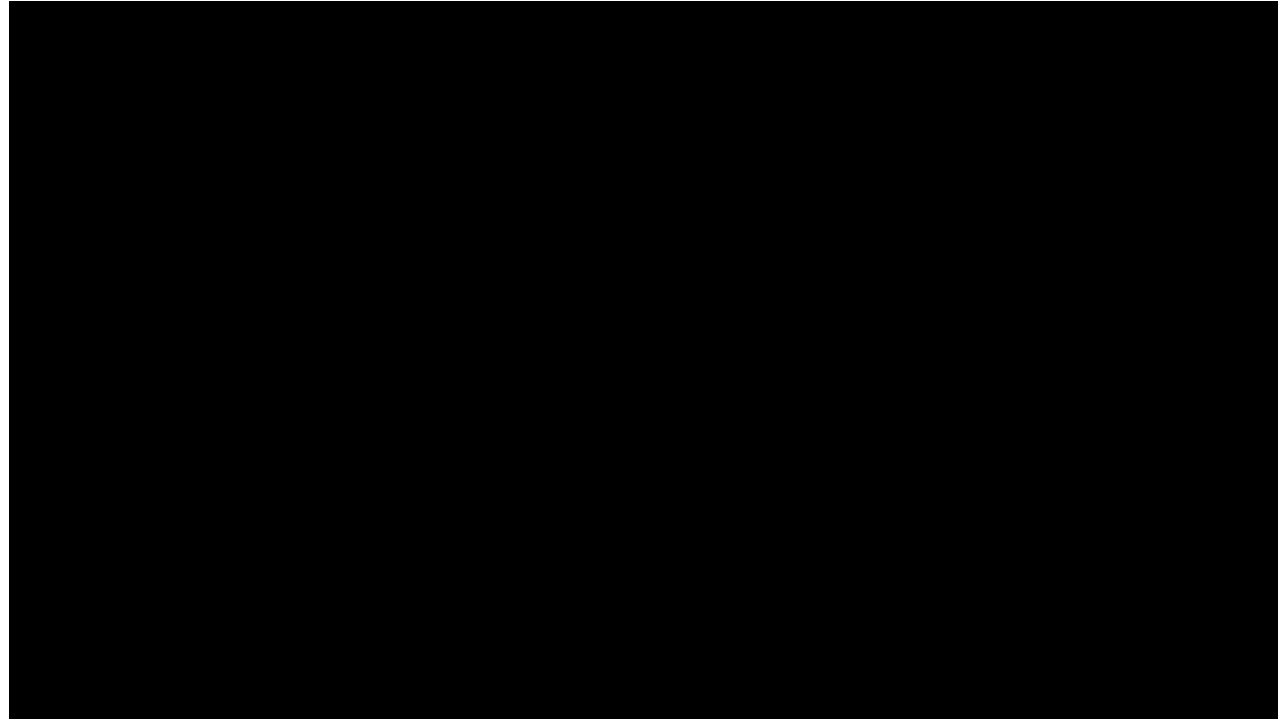
Automated Shoulder Surfing

- Steal your passcode with a glance:
 - Software used custom-coded video recognition algorithm tracks shadows from finger taps
 - Software analyses video recorded by google glass and manages to identify 4-digit PIN codes up to 3 meters away



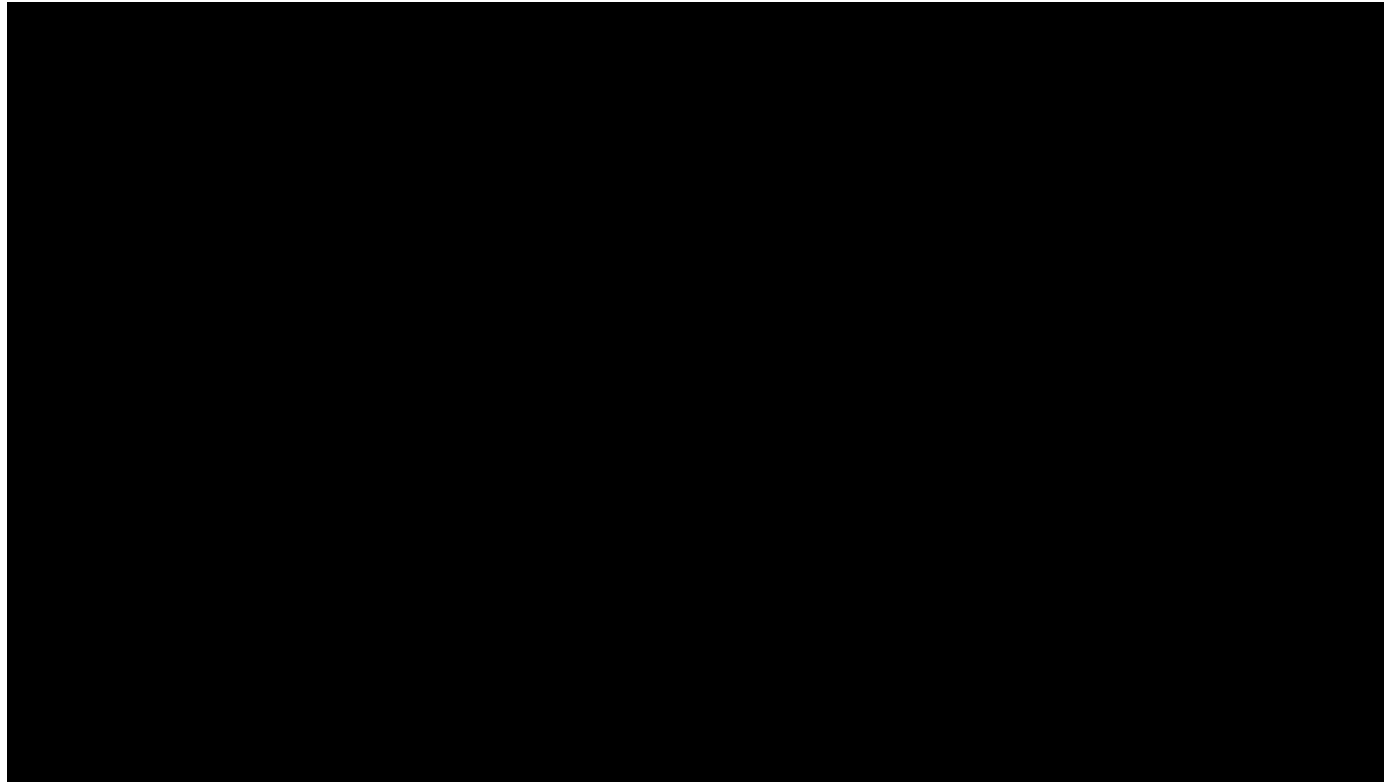
Defence Against Shoulder Surfing

- Defense:
 - Awareness of physical environment – ATMs, working on laptops, phone conversations
 - Security screens, privacy filter
 - Biometrics authentication
- 3M ePrivacy Filter Example:



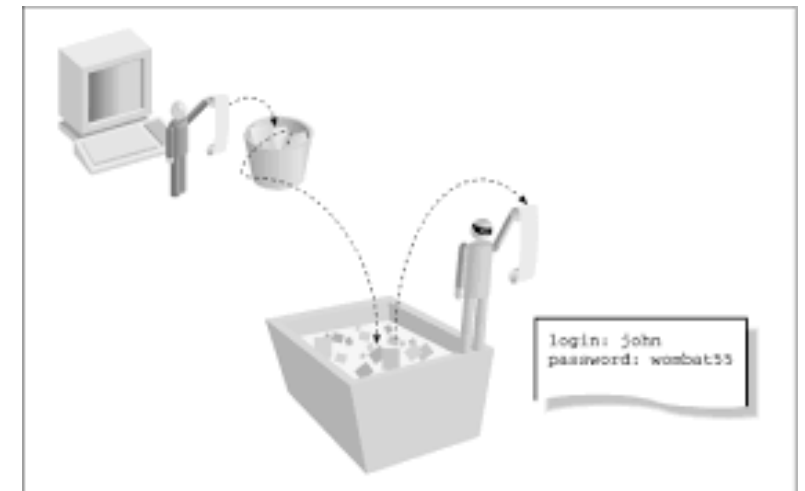
Defence Against Shoulder Surfing - 2

- Defense:
 - Google's AI privacy app – for smartphones
 - Detects stranger glancing at mobile over shoulder
 - Light weight machine learning model for rapid gaze detection
- Google Electronic Screen Protector:



Dumpster Diving Overview

- Discarded records of important info.
- Originated by phone phreaks
 - Precursor to hackers
- AT&T's monopoly days, before paper shredders became common
 - Phone phreakers used to organize regular dumpster runs against phone company plants and offices
- Target: discarded and damaged copies of AT&T internal manuals
 - Learned about phone equipment



Dumpster Diving Technique

- Go through someone's trash
- Recover copies of:
 - Credit card receipts
 - Bank account statements
 - Passwords, usernames and other sensitive information
 - Can be personal info (spoofing)
- Complements Social Engineering Tech
- Information obtained facilitates access

DISCOVERY



Sometimes, the greatest treasures
are found beneath piles of trash.

Defence Against Dumpster Diving

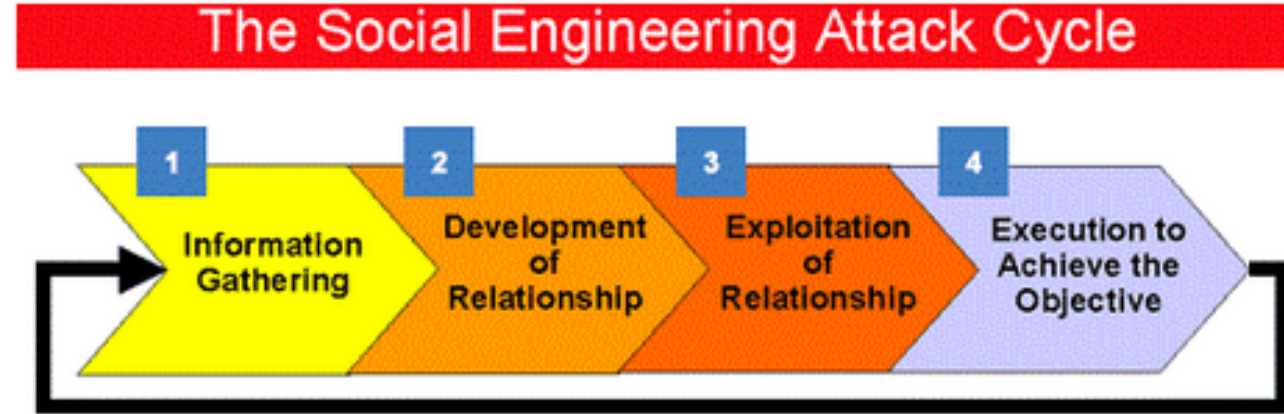
- **Defences**

- Destroy hard drive before discarding
- Destroy media (degaussing is not enough – inadequate scrambling)
- Shred paper with cross-cut shredder
- Physical security for trash



SOCIAL ENGINEERING

Social Engineering

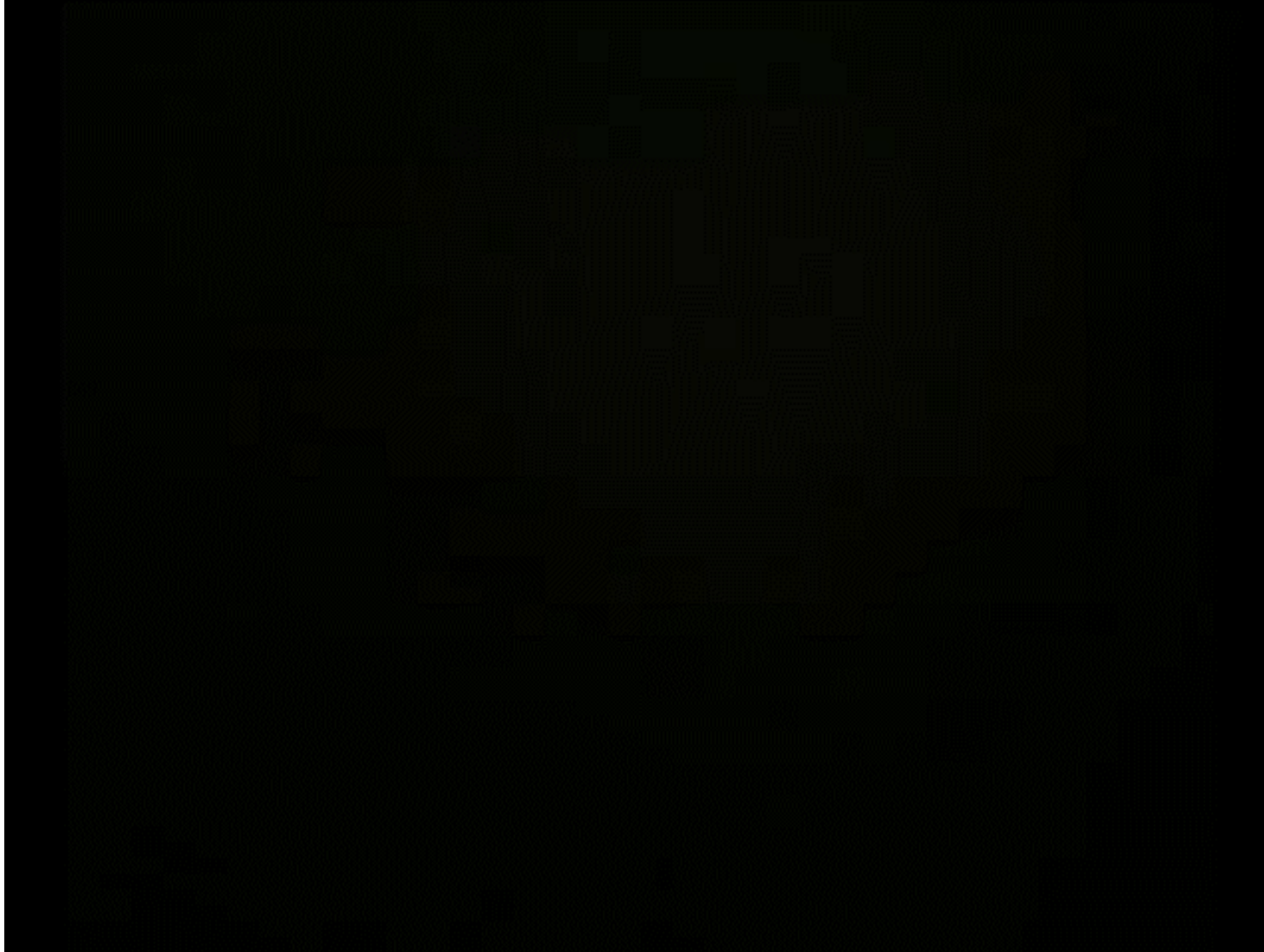


- Range of malicious activities designed to psychologically manipulate users into making mistakes concerning security
- Can work with or without technology
- It works because it exploits human vulnerabilities:
 - Desire to help or tendency to trust
 - Hope for a reward
 - Fear of making a mistake or getting into trouble
 - Fear of getting someone else in trouble

Social Engineering Example 1



Social Engineering Example 2



Social Engineering Attacks – 1/2

- **Phishing:**

- Seek to obtain personal/financial information, such as names, addresses and credit card information
- Use link shorteners (<https://bitly.com/>, <https://tinyurl.com/>) or embed links that redirect users to suspicious websites in URLs that appear legitimate
- Incorporates threats, fear and a sense of urgency in an attempt to manipulate the user into acting promptly
- Commonly pair malware as payload with phishing attacks

- **Pretexting:**

- Attackers focus on creating a good pretext, or a fabricated scenario
- Pretend to need certain info from target to confirm identity
- More advanced attacks will also try to manipulate their targets into performing an action that enables them to exploit the structural weaknesses of an organization or company (e.g. tailgating, impersonation)
- Unlike phishing emails, which use fear and urgency to their advantage, pretexting attacks rely on building a false sense of trust with the victim e.g. thru sympathy, appeal to sense of empathy

Social Engineering Attacks – 2/2

- **Baiting:**

- Similar to phishing attack but distinguishing factor is the use of enticement (e.g. free game download for login credentials)
- Not restricted to online schemes. Attackers can also focus on exploiting human curiosity via the use of physical media (e.g. dropped USB with malware)

- **Quid Pro Quo:**

- Promise a benefit in exchange for information; benefit usually in the form of a service
- E.g. “IT admin” provides a quick fix in exchange for the employee disabling their AV program and for installing “software update”

- **Tailgating (Piggybacking):**

- Attacks involve someone who lacks the proper authentication following an employee into a restricted area (also known as “piggybacking”)
- attackers can strike up conversations with employees and use this show of familiarity to successfully get past the front desk
- <https://www.todayonline.com/singapore/car-park-fee-evasion-rife-private-operators-lack-options-against-offenders>

Social Engineering Skills

- Hacker Talented at Social Engineering:
 - Able to use charm and influence effectively to manipulate and exploit human weaknesses
 - Builds up insider knowledge and develops trust relationships
 - Requires lots of patience
- A proficient attacker may spend days just to get information needed to complete a hack:
 - Learning internal company lingo and culture
 - Developing good connections with key people - security personnel and IT system support staff



Techniques and Tools

- **Most successful are calls to employees:**
 - Call help desk as new employee for help with a particular task
 - Angry manager calls lower-level system admin because password has suddenly stopped working
 - System admin calls employee to fix her account ... requires using her password
 - Employee in the field calls another employee for help with remote access
- **Tools:**
 - Call spoofing (<https://www.spoofcard.com/>)

The Social Engineering Toolkit

```
[---]      Homepage: https://www.trustedsec.com      [---]  
  
Welcome to the Social-Engineer Toolkit (SET). The one  
stop shop for all of your social-engineering needs.  
  
Join us on irc.freenode.net in channel #setoolkit  
  
The Social-Engineer Toolkit is a product of TrustedSec.  
  
Visit: https://www.trustedsec.com  
  
Select from the menu:  
  
1) Social-Engineering Attacks  
2) Fast-Track Penetration Testing  
3) Third Party Modules  
4) Update the Metasploit Framework  
5) Update the Social-Engineer Toolkit  
6) Update SET configuration  
7) Help, Credits, and About  
  
99) Exit the Social-Engineer Toolkit  
  
set> 
```

Telephone Spoof Example



**WATCH THIS HACKER
BREAK INTO
MY CELL PHONE ACCOUNT
IN 2 MINUTES**

Defence against Social Engineering

- Hard to defend against:
 - Weaknesses rooted in human nature
 - Many legitimate uses of “social engineering” (police, salespeople, etc.)
- User awareness education helps:
 - Do not give out sensitive info (e.g., usernames, passwords)
 - No reason a sysadmin would need your password
 - Do not trust caller ID, etc.
- Helpdesk should have better verification system
 - Ask for full name, employee ID, designation, office Tel no. etc.
 - Check and call back, never take at face value
 - Adhere to best practices/policies

Summary

- Objectives of Reconnaissance – find out all you can about target
- Reconnaissance Techniques and Tools: - Tech and No Tech
- Tech Techniques and Tools:
 - Whois, DNS Data View, Nslookup and Dig
 - Netcraft and Builtwith sites
 - Need to explore and try to see which (combination) is best
- No Tech Techniques and Tools:
 - Shoulder Surfing – can be used almost anywhere; user must be alert
 - Dumpster Diving – need physical access to trash; must have proper policies and practices regarding document and information disposal
 - Social Engineering – exploits human weaknesses; need user awareness, education and proper authentication policies and practices
- **Next Lecture – Google Hacking**

GOOGLE HACKING

Google Hacking Introduction

- Using Google to help in Reconnaissance
 - Not hacking Google
- Main benefits:
 - Low profile and passive – little or no exposure for attacker
 - Ranked google results
- Search to be reasonably precise – specific keywords ≤ 10
- Use **search operators (basic and advanced)**
- Attacker has password encrypted your file and only the hashed password value is known
 - Cannot reverse because hashes are one-way functions
 - What can you do?!

Google Hacking Passwords

- Google it!
- Even hashes from passwords:
 - Google the (MD5) hash value
 - <https://www.miraclesalad.com/webtools/md5.php> (Hash generator)
 - <https://10015.io/tools/md5-encrypt-decrypt> (Hash generator & cracker – limited)
 - Try with 20f1aeb7819d7858684c898d1e98c1bb (Anthony),
83ec45960b80c035a0068df1d9df5aa8 (technology)
- Note that there are other hash functions:
 - SHA-1 (<https://10015.io/tools/sha1-encrypt-decrypt>)
 - SHA-256 (<https://crackstation.net/> ; <https://passwordrecovery.io/sha256/>)
- Hash crackers work based on lookup tables

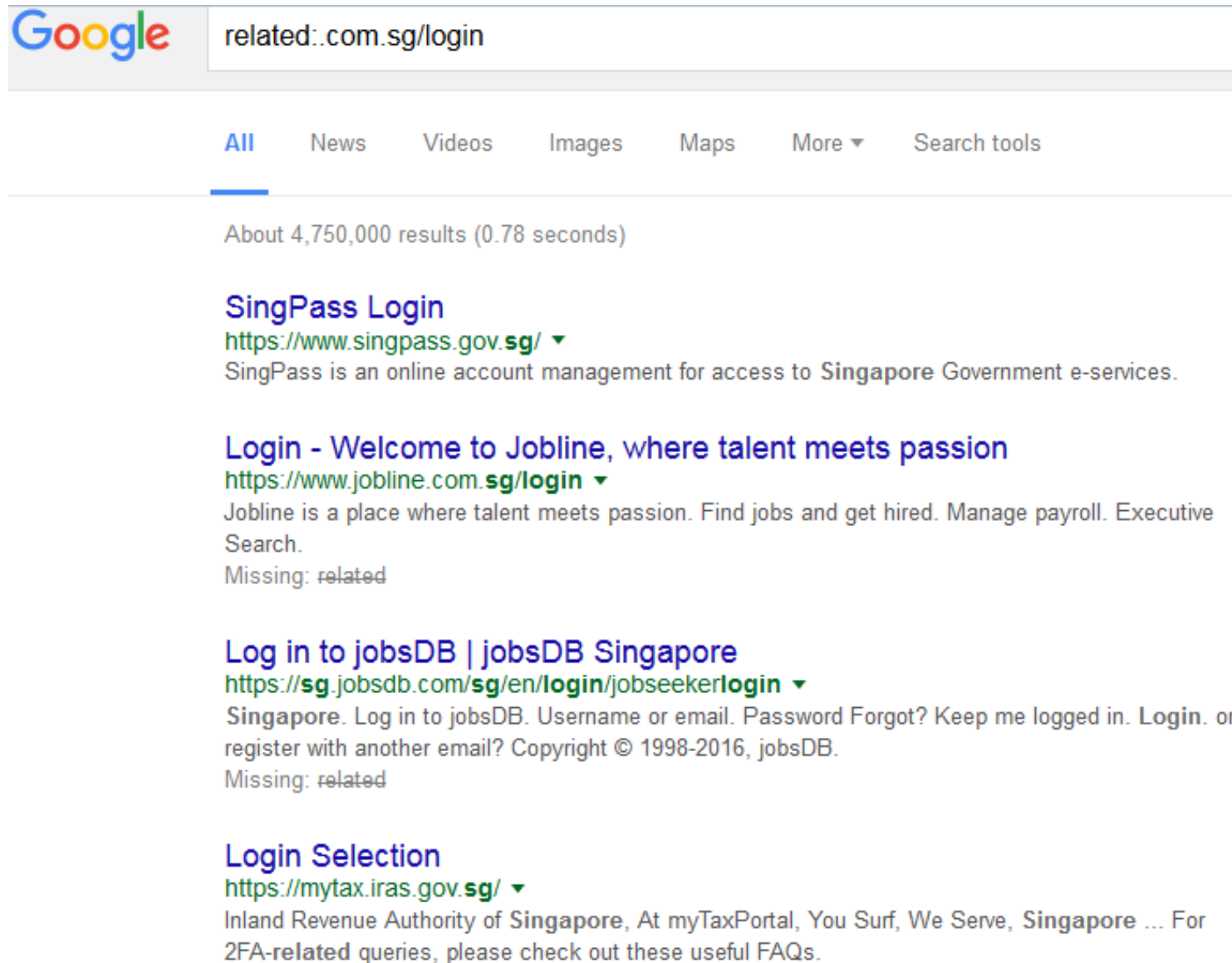
Basic Search Operators

- Literal match (“ ”)
 - Search for exact phrase in quotes; e.g. “metamorphic engines”
 - Wildcards represented by * e.g., “* institute of technology”
 - Google search is not case-sensitive
- NOT (-): Filter out sites that include term (-term or -“term”)
- AND (+): Include sites that contain term(s)
- OR (|): Include sites that contain one or more term(s)
- Synonym (~):
 - Searches for target word and includes words with similar meaning e.g.,
~inexpensive shops in Singapore, ~evasive malware
- Range (..):
 - Specify search range e.g. singapore pre-owned car (\$100000..\$150000)

Advanced Search Operators

- Google group operators include:
 - **allintitle:** restricts results to those containing all the query terms you specify in the title e.g. `allintitle:hacking atm`
 - **group:** allows you to find specific groups related to a given topic e.g., `group:*.hacking.*`
 - **related:** allows you to find web pages similar to the specified web page e.g. `related:"password sniffing"` (no space after :)
 - **intext:** restricts results to documents containing specified term in the text e.g. `intext:bank password` (no space after :)
 - **inurl:** restricts results to those containing term in URL e.g., `inurl:"password list"` (no space after :)
 - **filetype:** restricts results to those containing file type specified e.g., `passwd filetype:txt` (no space after :)
- Reference URL: https://www.googleguide.com/advanced_operators_reference.html
- <https://www.freecodecamp.org/news/google-dorking-for-pentesters-a-practical-tutorial/>

Google Hacking Example 1



Google related:.com.sg/login

All News Videos Images Maps More ▾ Search tools

About 4,750,000 results (0.78 seconds)

SingPass Login
<https://www.singpass.gov.sg/> ▾
SingPass is an online account management for access to Singapore Government e-services.

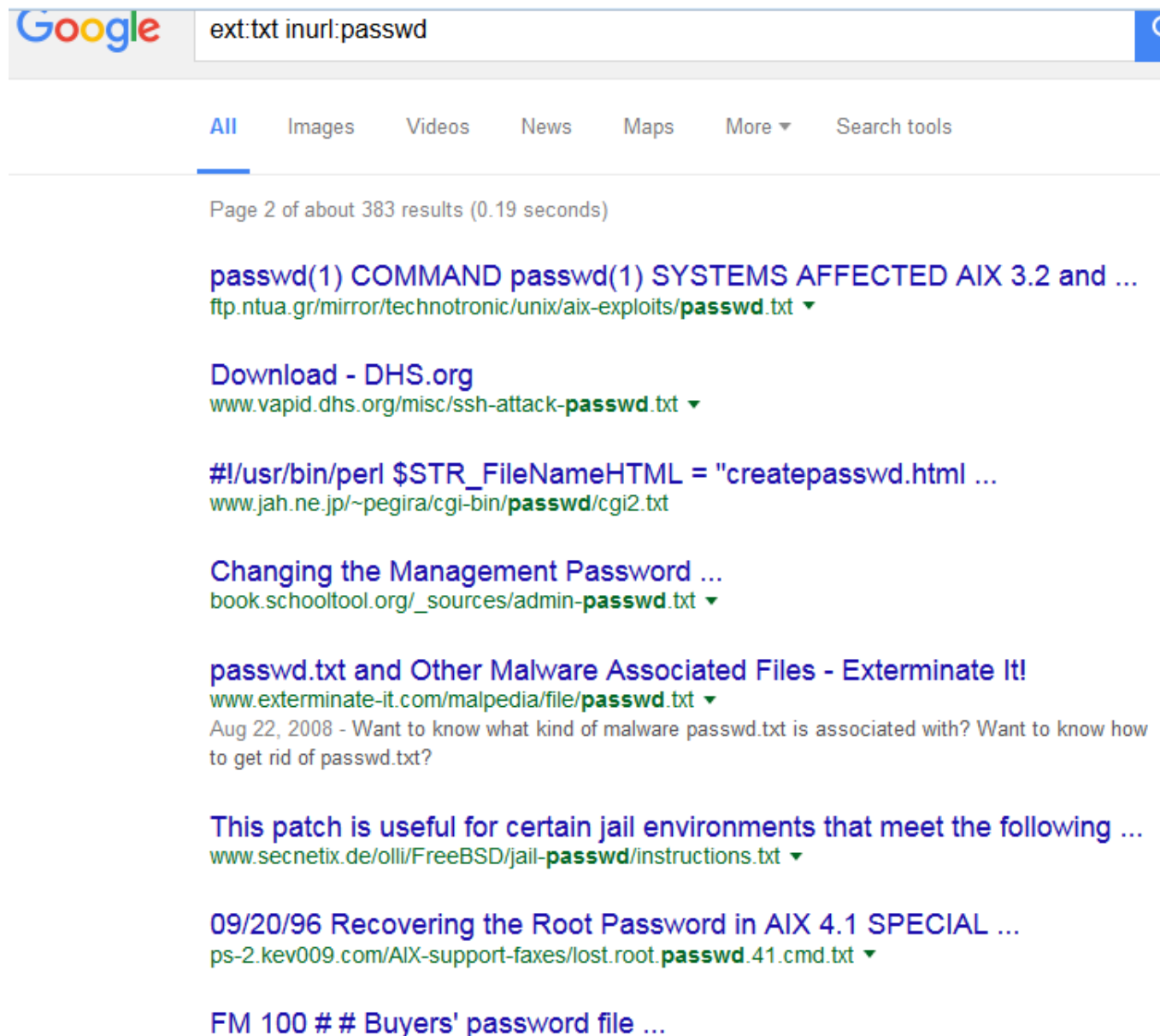
Login - Welcome to Jobline, where talent meets passion
<https://www.jobline.com.sg/login> ▾
Jobline is a place where talent meets passion. Find jobs and get hired. Manage payroll. Executive Search.
Missing: related

Log in to jobsDB | jobsDB Singapore
<https://sg.jobsonline.com.sg/en/login/jobseekerlogin> ▾
Singapore. Log in to jobsDB. Username or email. Password Forgot? Keep me logged in. Login. or register with another email? Copyright © 1998-2016, jobsDB.
Missing: related

Login Selection
<https://mytax.iras.gov.sg/> ▾
Inland Revenue Authority of Singapore, At myTaxPortal, You Surf, We Serve, Singapore ... For 2FA-related queries, please check out these useful FAQs.

**Some logins
can be
bypassed
with SQLI**

Google Hacking Example 2



Google search results for `ext:txt inurl:passwd`.

Page 2 of about 383 results (0.19 seconds)

- [passwd\(1\) COMMAND passwd\(1\) SYSTEMS AFFECTED AIX 3.2 and ...](#)
[ftp.ntua.gr/mirror/technotronic/unix/aix-exploits/passwd.txt](#)
- [Download - DHS.org](#)
[www.vapid.dhs.org/misc/ssh-attack-passwd.txt](#)
- [#!/usr/bin/perl \\$STR_FileNameHTML = "createpasswd.html ...](#)
[www.jah.ne.jp/~pegira/cgi-bin/passwd/cgi2.txt](#)
- [Changing the Management Password ...](#)
[book.schooltool.org/_sources/admin-passwd.txt](#)
- [passwd.txt and Other Malware Associated Files - Exterminate It!](#)
[www.exterminate-it.com/malpedia/file/passwd.txt](#)
Aug 22, 2008 - Want to know what kind of malware passwd.txt is associated with? Want to know how to get rid of passwd.txt?
- [This patch is useful for certain jail environments that meet the following ...](#)
[www.secnetix.de/olli/FreeBSD/jail-passwd/instructions.txt](#)
- [09/20/96 Recovering the Root Password in AIX 4.1 SPECIAL ...](#)
[ps-2.kev009.com/AIX-support-faxes/lost.root.passwd.41.cmd.txt](#)
- [FM 100 # # Buyers' password file ...](#)

What is ext?

Google Hacking Exercise 3

- Spend 5 minutes on this simple exercise

ext:txt inurl:passwd

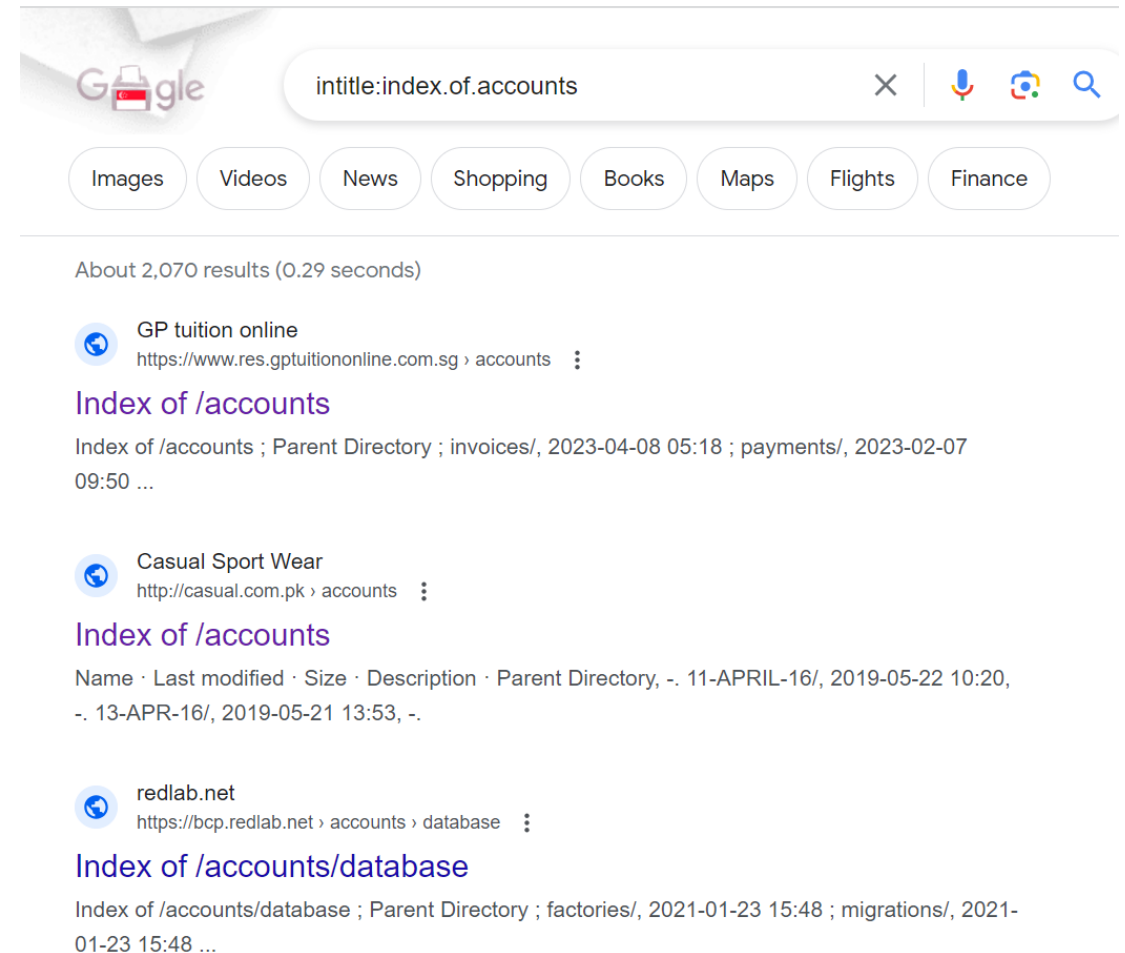
ext:txt inurl:password

ext:csv inurl:passwd

ext:xlsx inurl:password

Google Hacking Example 4

- Search for directory containing accounts
- Get files potentially containing account records
- **intitle:index.of.accounts**



Google Dorks

- A google dork is a search query:
 - Search string that uses advanced search operators
 - Find info not readily available on website via basic search
- Google Dorking:
 - Info retrieved not for public
 - Info available because not adequately secured
- Google Hacking Database (GHDB):
 - <https://www.exploit-db.com/>
 - <https://www.exploit-db.com/google-hacking-database/>
 - Try out these dorks in your e-learning labs

Google Hacking Example 5

- `inurl:"viewerframe?mode=motion"`
- This dork finds wireless camera that is accessible from the web
 - <http://61.211.241.239/ViewerFrame?Mode=Motion&Resolution=640x480&Quality=Standard&Interval=30&Size=STD&PresetOperation=Move&Language=1>
 - <http://shiretoko.miemasu.net/CgiStart?page=Single&Mode=Motion>
- The interesting part is that some of these cameras do not allow users to change the default administrative username and pass.

`inurl:"viewerframe?mode=motion"`

Web Videos Apps Shopping Images More ▾ Search tools

About 1,160 results (0.32 seconds)

Network Camera PoolCam

74.94.148.163:8080/ViewerFrame?Mode=Motion ▾

Image Quality. *, Favor Clarity · Standard · Favor Motion. Image Size. x1.0 · x1.5.

Buffered Image. Multi-Camera · Top Page · Help. PoolCam.

麒麟 - Network Camera fLfŠf

60.45.63.26/ViewerFrame?Mode=Motion ▾

パン/チルト.ズーム.テレワイド.フォーカス.近く自動遠く.プリセット.センター・カナエ・アミ.明るさ. -- 標準 - +. 解像度. *, 640x480 · 320x240 · 160x120. 画質.

Network Camera Pecky

212.96.169.238/ViewerFrame?Mode=Motion ▾

Image Quality. Favor Clarity. *, Standard · Favor Motion. Image Size. x1.0 · x1.5.

Buffered Image. Multi-Camera · Top Page · Help. Pecky.

Network Camera Suite1 - Top Page

75.145.222.133:7505/ViewerFrame?Mode=Motion ▾

Image Quality. Favor Clarity. *, Standard · Favor Motion. Image Size. x1.0 · x1.5.

Buffered Image. Capture · Multi-Camera · Top Page · Help. Suite1.

Network Camera WebCam1 - Top Page

24.240.181.138:8181/ViewerFrame?Mode=Motion ▾

Image Quality. Favor Clarity. *, Standard · Favor Motion. Image Size. x1.0 · x1.5.

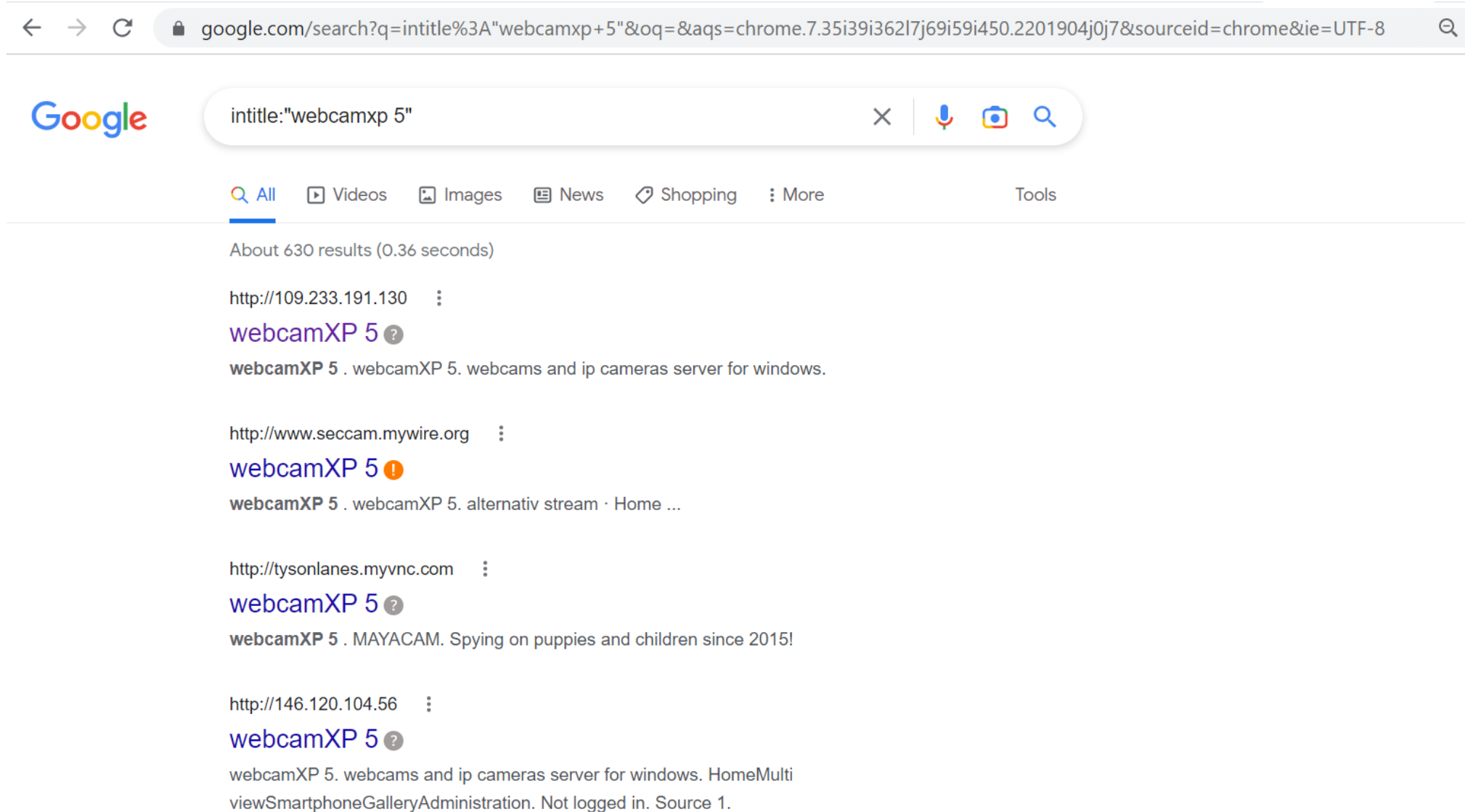
Buffered Image. Capture · Multi-Camera · Top Page · Help. WebCam1.

Google Hacking Example 5



[Watch the real-time monitoring video](#)

Google Hacking Example 6 - intitle:"webcamxp 5"



The screenshot shows a Google search interface with the query "intitle:"webcamxp 5"". The search bar includes icons for voice search, image search, and a magnifying glass. Below the search bar, navigation links for "All", "Videos", "Images", "News", "Shopping", and "More" are visible, along with a "Tools" link. The search results indicate "About 630 results (0.36 seconds)".

The first result is from <http://109.233.191.130> and is titled "webcamXP 5". The snippet reads: "webcamXP 5 . webcamXP 5. webcams and ip cameras server for windows."

The second result is from <http://www.seccam.mywire.org> and is titled "webcamXP 5". The snippet reads: "webcamXP 5 . webcamXP 5. alternativ stream · Home ..."

The third result is from <http://tysonlanes.myvnc.com> and is titled "webcamXP 5". The snippet reads: "webcamXP 5 . MAYACAM. Spying on puppies and children since 2015!"

The fourth result is from <http://146.120.104.56> and is titled "webcamXP 5". The snippet reads: "webcamXP 5. webcams and ip cameras server for windows. HomeMulti viewSmartphoneGalleryAdministration. Not logged in. Source 1."

Google Hacking Exercise 7

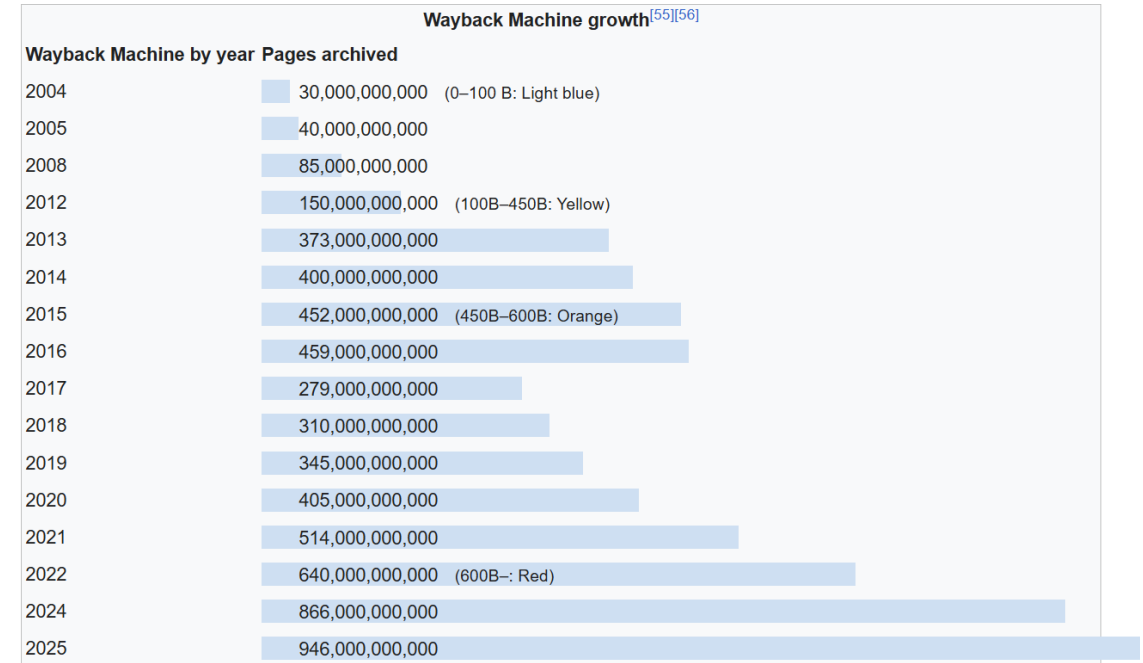
SIT Internal

➤ <http://vroomshoopwebcam.mine.nu/>



Google Hacking Tools – Wayback Machine

- A digital archive of the World Wide Web
- Founded by the Internet Archive, an American nonprofit organization based in San Francisco, California
- Launched for public access in 2001
- Allow users to go "back in time" to see how websites looked in the past
- Earliest archives go back at least to 1995
- <https://web.archive.org/>



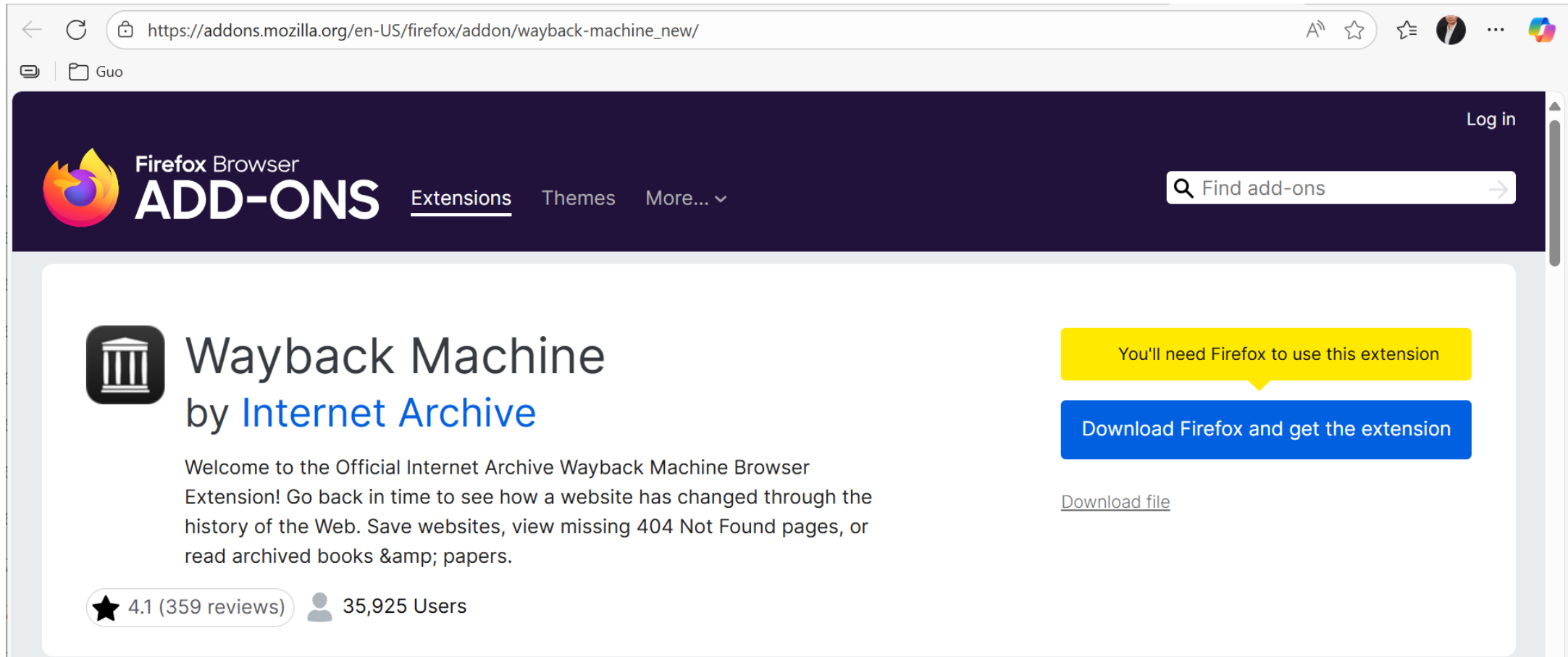
Source: https://en.wikipedia.org/wiki/Wayback_Machine

Google Hacking Tools – Wayback Machine

- Wayback Machine APIs
 - Supports a number of different APIs to make it easier for developers to retrieve information about Wayback capture data.
 - https://archive.org/help/wayback_api.php
 - This page is subject to change frequently, please check back for the latest info.

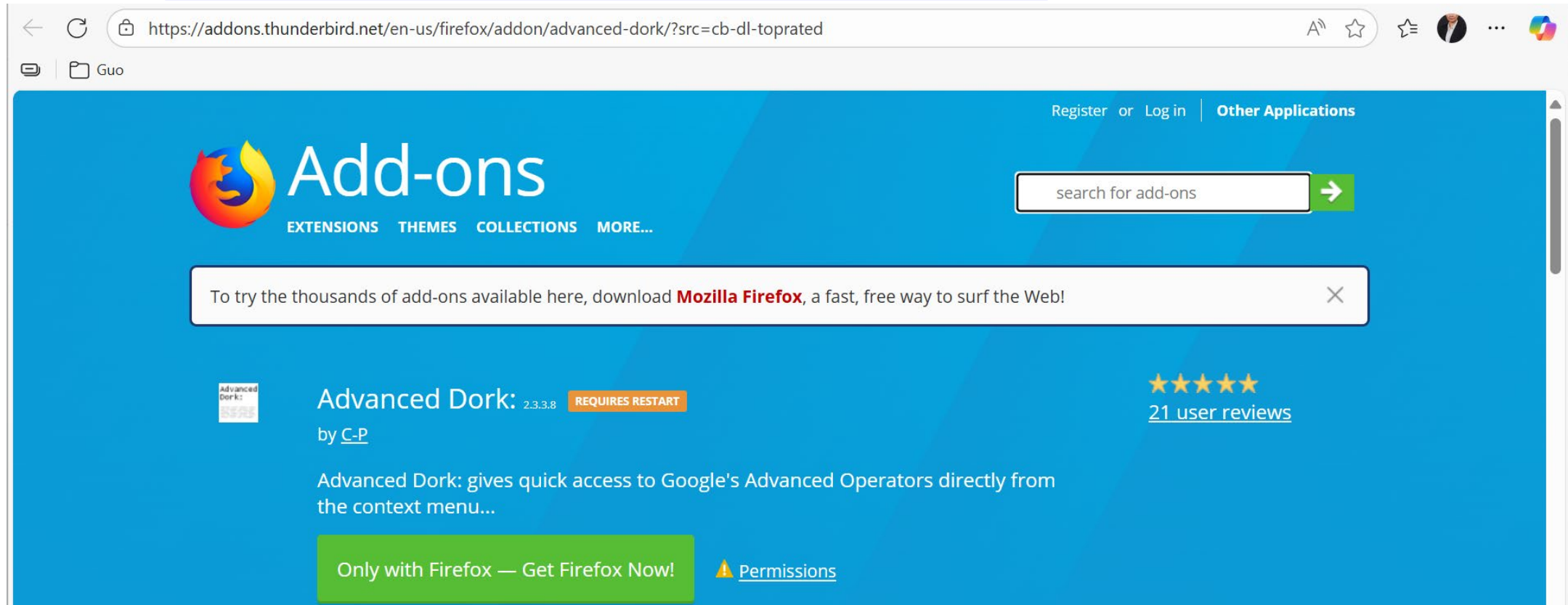
Google Hacking Tools – Wayback Machine

- Firefox addon from: https://addons.mozilla.org/en-US/firefox/addon/wayback-machine_new/



Google Hacking Tools - Advanced Dork

- *Advanced Dork* – a Firefox extension designed to give quick access to Google's Advanced Operators.
- Firefox addon from: <https://addons.thunderbird.net/en-us/firefox/addon/advanced-dork/?src=cb-dl-toprated>, <https://addons.mozilla.org/en-US/firefox/addon/dorkit/>



Google Hacking Tools - Wikto

- *Wikto* – a Windows based web server assessment tool that uses the Google hacking database (GHDB).
- It checks for vulnerabilities in web servers.
- This tool requires a Google developer license.
- Needs .NET;
- Download from: <https://github.com/sensepost/wikto>



Stop
Quit
Pause

Target selection

IP / DNS name
80 Port ☐ SSL

Trigger Control

1000.000 ☒ Optimised

Reset Update
Clear DB Show All

Export Results
Load Nikto Database

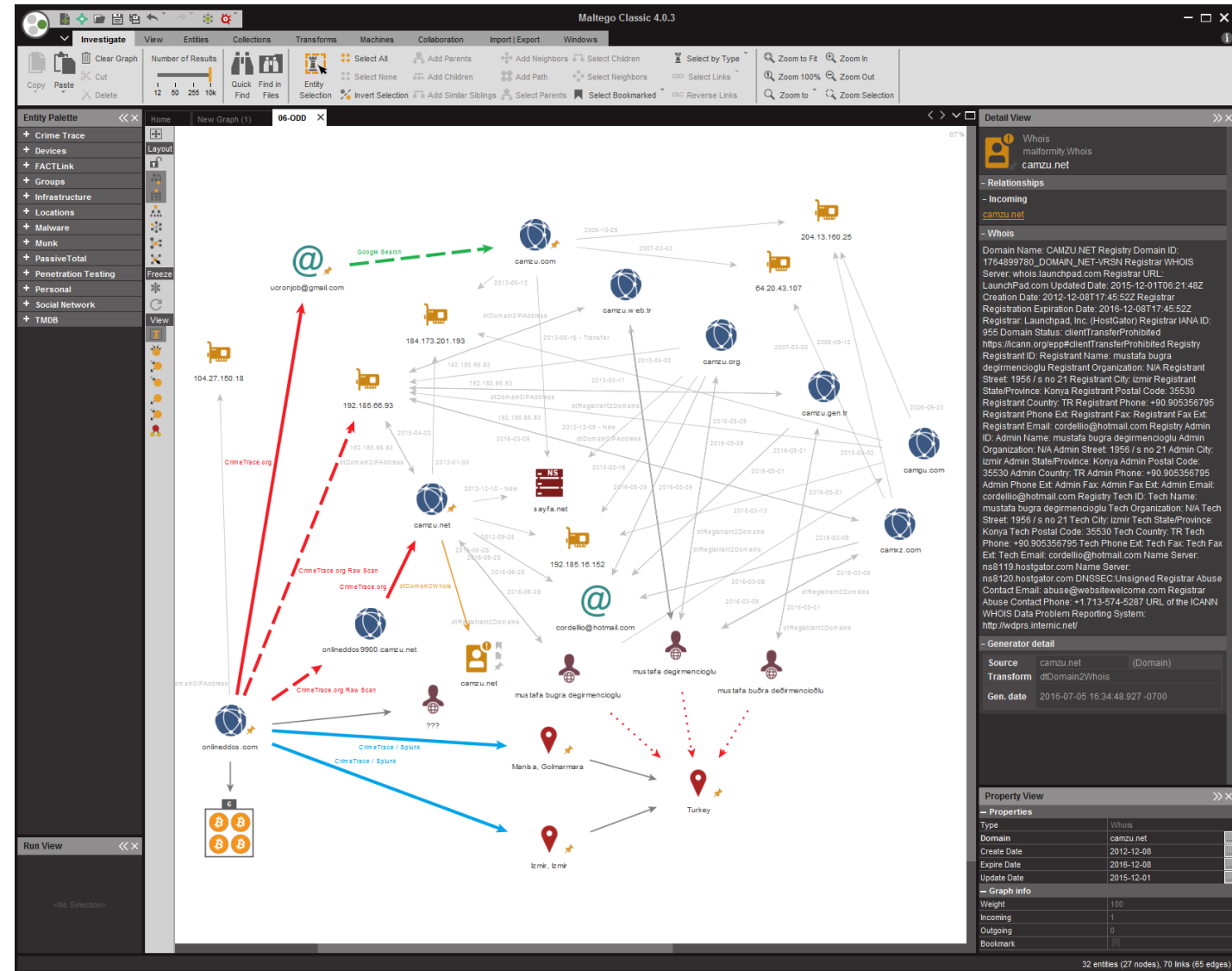
Trigger	Request
Celerra Web Manager	/
default Tomcat	/
default Tomcat	/
EMC ControlCenter	/
instead of the website	/
Test Page for Apache	/
Directory Listing for /wdk/	/webtop/wdk/
System Management Homepage	/cpqlogin.htm
This is a private system	/cpqlogin.htm
DHost HTTP Server	/
AnswerBook	/
Allaire Corporateion	/
Cisco IP Phone	/
Jaguar CTS	/
Jrun Management Console	/
Lantronix	/
Storage Management	/
Welcome to the JMC	/
XEROX WORKCENTRE	/
The site you were trying to reach d...	/

Nikto Results

Type	Weight	Trigger	Request
	100	Celerra Web Manager	/
	100	default Tomcat	/
	100	default Tomcat	/
	100	EMC ControlCenter	/
	100	instead of the website	/
	100	Test Page for Apache	/
	100	Directory Listing for ...	/webtop/wdk/
	100	System Manageme...	/cpqlogin.htm

HTTP Request

Maltego is an open source intelligence and graphical link analysis tool for gathering and connecting information for investigative tasks



<https://www.maltego.com/>

The screenshot displays the Maltego website's homepage. At the top, a dark navigation bar contains the Maltego logo, links for PRICING, TOOLS, RESOURCES, INDUSTRIES, and INVESTIGATE, a user profile icon, a SIGN IN button, and a GET A DEMO button. Below this, a horizontal menu features five tabs: Monitor, Investigate (which is currently selected), Customize, Manage, and Upskill. The main content area is divided into two columns. The left column, under the 'Investigate' tab, features two cards: 'MALTEGO SEARCH' with an orange icon and a description about OSINT searches, and 'MALTEGO MONITOR' with a purple icon and a description about real-time data monitoring. The right column features two cards: 'MALTEGO GRAPH' with an orange icon and a description about deep investigations, and 'MALTEGO EVIDENCE' with a blue icon and a description about uncovering hidden truths in social media datasets.

← → ↻ 🌐 maltego.com ☆ ⓘ ⋮

MALTEGO PRICING TOOLS ▾ RESOURCES ▾ INDUSTRIES ▾ INVESTIGATE 👤 SIGN IN GET A DEMO

Monitor Investigate Customize Manage Upskill



MALTEGO SEARCH

Run quick OSINT searches on suspects and threat actors with data from social media, the dark web, identity databases, and breach data



MALTEGO MONITOR

Monitor real-time data and use AI-powered sentiment analysis to detect and assess potential and ongoing public safety disruptions and cyber threats



MALTEGO GRAPH

Conduct deep investigations into complex OSINT cases and cyber threats with access to all external and internal data



MALTEGO EVIDENCE

Uncover hidden truths in large social media datasets with customized crawling profiles

Google Hacking Uses

- *Information Disclosure* – Google can gather sensitive and private information and contents as well as intellectual property assets
- *Vulnerability Assessment* – Google allows you to identify vulnerable resources published on the Internet. These mainly affect web-based devices such as web servers, application servers and network devices with a web-based interface
- *Social Engineering* – Google can also be used to map information from the virtual world to the real world in order to perform social engineering testing

Supplement with other tools like Wikto and Maltego

Online Social Engineering

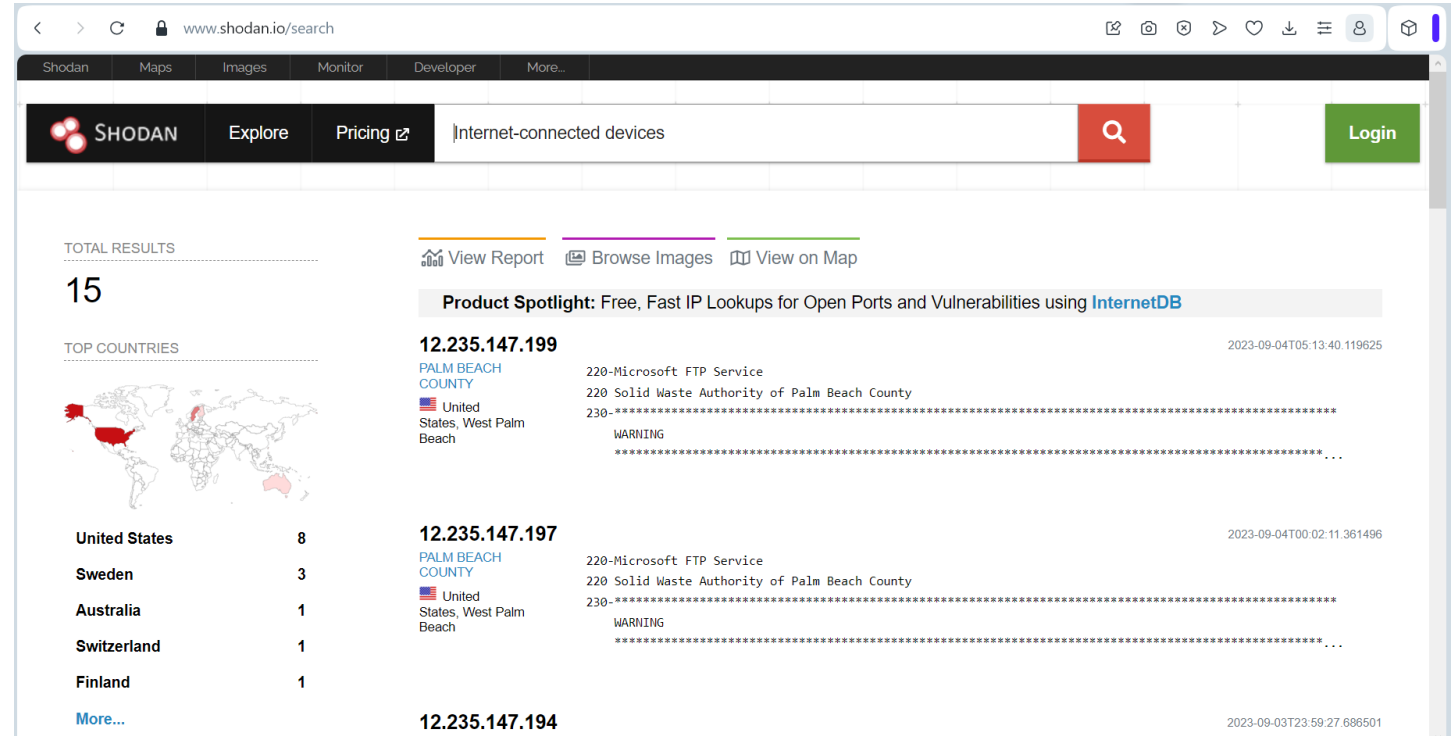
- Google Dork query may reveal useful info:
 - Employee contact info
 - Clues about corporate culture/lingo
 - Business partners
 - Recent mergers and acquisitions
 - Signatures (that can be forged)
 - Financial information (competitor's edge)

Why they are useful?

Internet-connected devices

Shodan: search engine for
Internet-connected devices

<https://www.shodan.io/>



The screenshot shows the Shodan search engine interface. The search bar at the top contains the query "Internet-connected devices". The results page displays 15 total results. On the left, a world map highlights the top countries: United States (8), Sweden (3), Australia (1), Switzerland (1), and Finland (1). The main results list shows three entries, all from Palm Beach County, Florida, United States, identified as "220-Microsoft FTP Service". The first entry is for IP 12.235.147.199, the second for 12.235.147.197, and the third for 12.235.147.194. Each entry includes a "WARNING" message and a timestamp. The interface also features navigation links like "Shodan", "Maps", "Images", "Monitor", "Developer", and "More...", as well as buttons for "Explore", "Pricing", "View Report", "Browse Images", "View on Map", and "Login".

Shodan | Maps | Images | Monitor | Developer | More...

SHODAN | Explore | Pricing | Internet-connected devices | Login

TOTAL RESULTS
15

TOP COUNTRIES

United States 8
Sweden 3
Australia 1
Switzerland 1
Finland 1
More...

View Report | Browse Images | View on Map

Product Spotlight: Free, Fast IP Lookups for Open Ports and Vulnerabilities using [InternetDB](#)

12.235.147.199 2023-09-04T05:13:40.119625
PALM BEACH COUNTY
United States, West Palm Beach
220-Microsoft FTP Service
220 Solid Waste Authority of Palm Beach County
230-*****
WARNING

12.235.147.197 2023-09-04T00:02:11.361496
PALM BEACH COUNTY
United States, West Palm Beach
220-Microsoft FTP Service
220 Solid Waste Authority of Palm Beach County
230-*****
WARNING

12.235.147.194 2023-09-03T23:59:27.686501

Defences Against Google Hacking

- Use Google hacking techniques to uncover your own security problems (recall use of google hacking as vulnerability assessment)
- Proper configuration for web-based devices
 - Use strong authentication not defaults
- Have a good corporate security policy e.g., policy for asset protection
 - Removing sensitive info does not help
 - Google cache (<meta name="robots" content="noarchive">)
 - Wayback Machine (opt out e.g., Quora)
- Educate users – best practices
- Use robots.txt so Web pages not indexed
 - Well-behaved crawlers will respect these, but...
 - Also a sign to attackers of sensitive data
- Use a combination of the above

The spam

SIT Internal

You have been invited to SIT Virtual Zoom Meeting. Mark your calendar now!

 Zoom Meeting <zooms-n0reply@singaporetech.com.sg>
To:  Raymond Chan Ching Bon

Today at 9:30 AM

 This message is high priority.

CAUTION: This email originated from outside of SIT. Do not click links or open attachments unless you recognise the sender and know the content is safe.



Dear Raymond Chan Ching Bon,

You Have Been Invited to SIT Virtual Conference Tomorrow

Please login and download the invite to your calendar

The link only works for the direct recipients of this message.
Sign in with your account to access the download invite

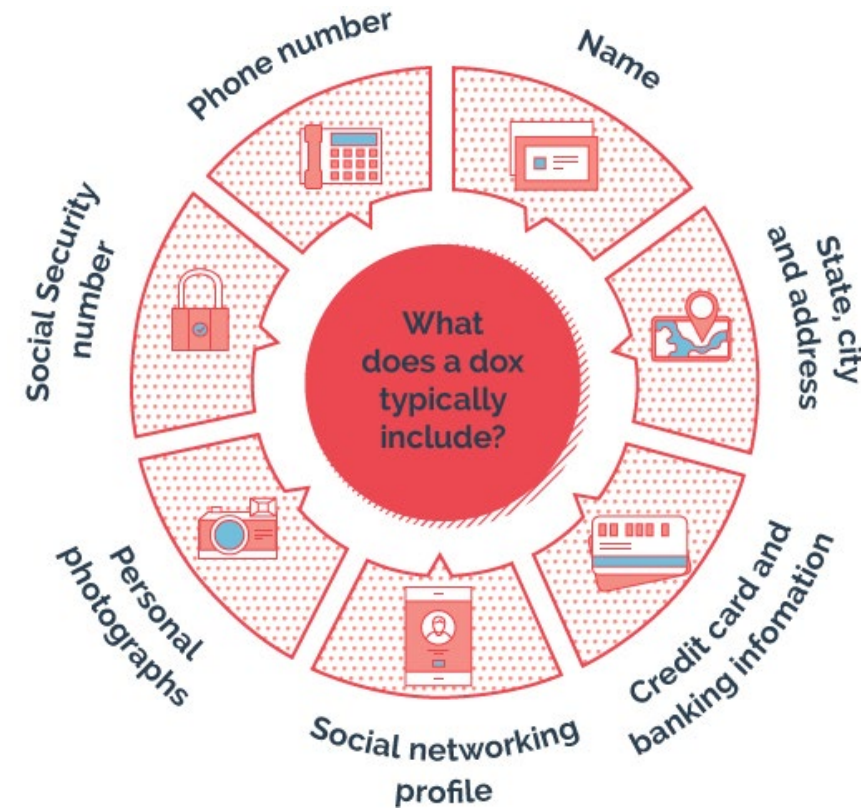
[Add to Calender](#)

This email was sent to raymond.chan@singaporetech.edu.sg
© 2019 ZOOM Video Communications, nlc. All right reserved
[Read our privacy policy](#)

DOXING

What is Doxing?

- Doxing is the process of gathering or deducing information about someone using sources on the internet.
- Its name is derived from 'Document Tracing'
- Information could include name, age, email, address, telephone number, photographs etc.
- Some sites support a degree of automation



**E.g. Whose camera did I hack?
Is person X masquerading as
person Y?**

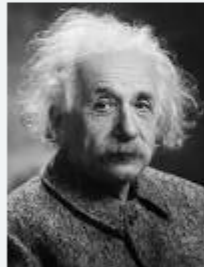
Doxing Tools

- Personal information:
 - People Search: <https://whitepages.sg>, <https://webmii.com>, <https://com.lullar.com>, <https://pipl.com>
 - Photo Search: <https://tineye.com> , <https://images.google.com/>
 - Find contact: <https://www.411.com/>, <https://whitepages.com> (USA)
- IP - Address information:
 - Address from IP: <https://whatismyipaddress.com/ip-lookup>
 - Geolocation: <https://www.iplocation.net/>
- Open Source Intelligence:
 - Maltego Chlorine: download from <https://www.paterva.com/web6/products/download.php>
 - Board Reader: <https://boardreader.com/> (posts made by or involving name)

Doxing Demo 1

**TinEye**[SEARCH](#)[PRODUCTS](#) ▼[LABS](#)[ABOUT](#)<http://tineye.com>

Upload or enter Image URL

[Download the TinEye extension](#) for Firefox

JPEG, 101x134, 3.3 KB

2,746 Results

98 results belong to image collections.

Searched over **12.559 billion images**.

for image: Albert Einstein.jpg

Results will expire after 72 hours for unregistered users. [Login](#) or [Create a Free Account](#)TinEye is free to use for non-commercial purposes. See our [Products and APIs](#) for comm

Sort by: Best match



« Prev

1

2

3

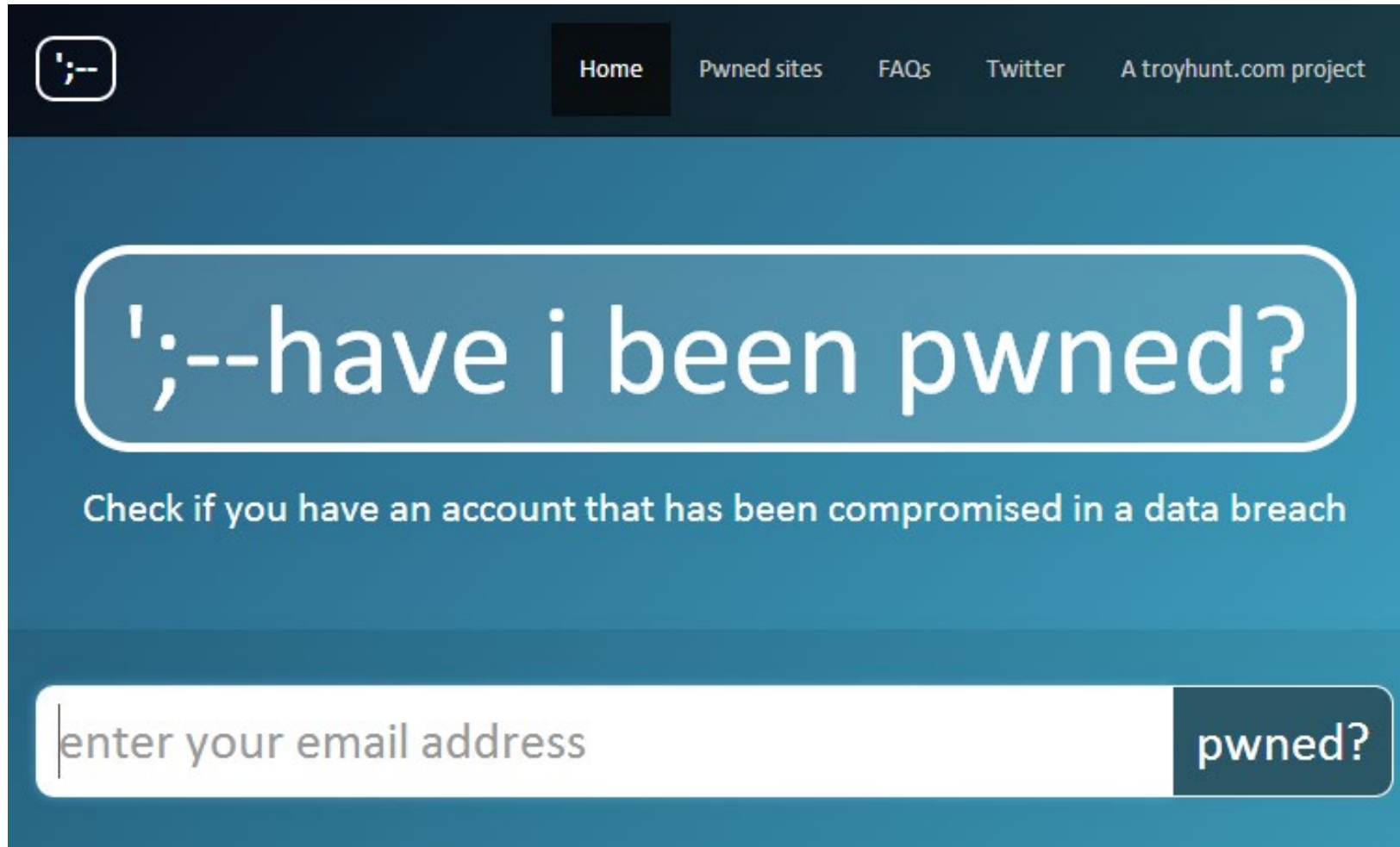
...

274

275

Next »

Doxing more info



The screenshot shows the homepage of the 'have i been pwned?' website. The header is dark blue with a logo on the left and navigation links: Home, Pwned sites, FAQs, Twitter, and A troymhunt.com project. The main content area has a blue background. A large white rounded rectangle contains the text 'have i been pwned?'. Below this, a smaller white rounded rectangle contains the text 'Check if you have an account that has been compromised in a data breach'. At the bottom, there is a white input field with the placeholder text 'enter your email address' and a dark blue button labeled 'pwned?'.

What is its url? <https://haveibeenpwned.com/>

Doxing Demo 2

<http://whatismyipaddress.com/ip-lookup>

137.132.21.27

Lookup IP Address

Details for 137.132.21.27

IP: 137.132.21.27

Decimal: 2307134747

Hostname: ddu.nus.edu.sg

ASN: 7472

ISP: National University of Singapore

Organization: Computer Centre

Services: None detected

Type: [Broadband](#)

Assignment: [Static IP](#)

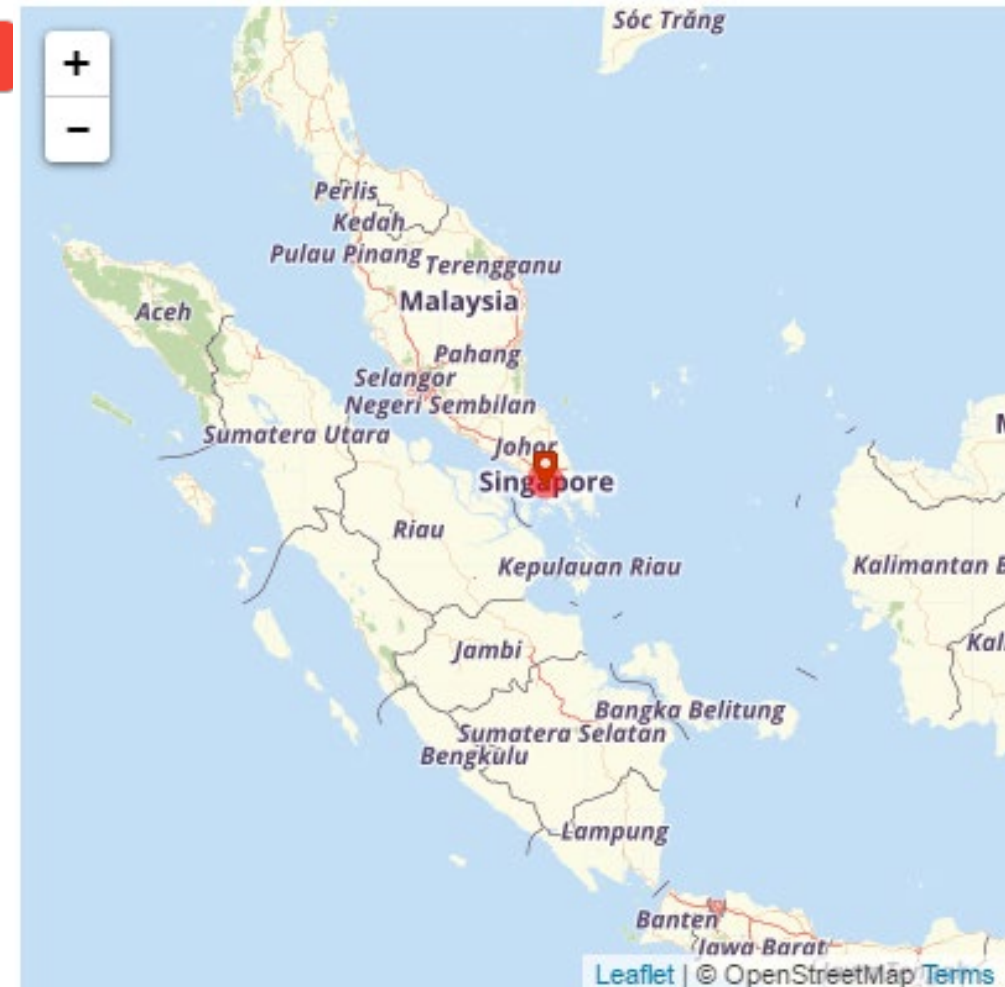
Blacklist: [Click to Check Blacklist Status](#)

Continent: Asia

Country: Singapore 

Latitude: 1.3667 (1° 22' 0.12" N)

Longitude: 103.8 (103° 47' 60.00" E)

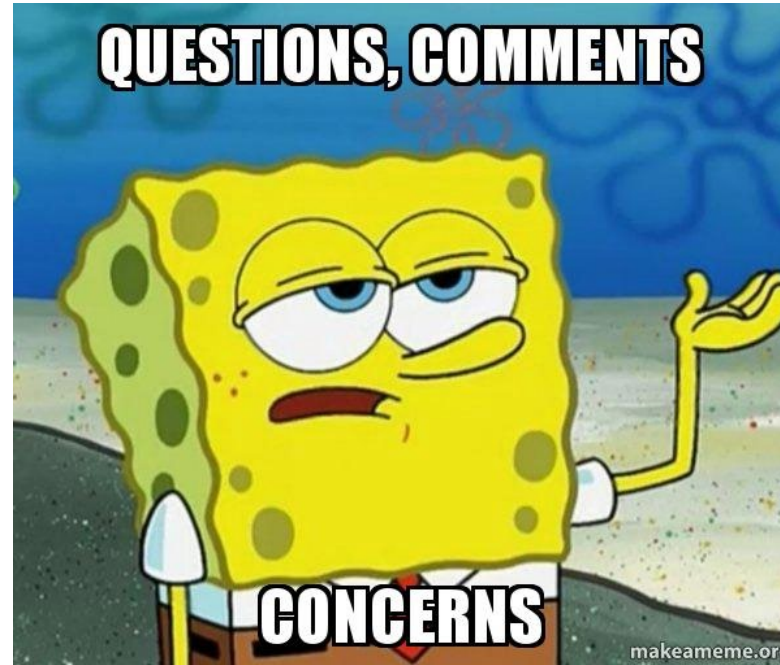


Reconnaissance Summary

Technique	Tools / URLs
Preliminary Reconnaissance	Whois, Netcraft, DNS Data View, nslookup, dig, Wayback Machine, Wikto
Shoulder Surfing, Dumpster Diving, Social Engineering	Google Glass, Telespoof
Google Hacking	https://www.googleguide.com/advanced_operators_reference.html https://www.exploit-db.com/google-hacking-database/ , Wikto, Wayback Mach
Doxing – Personal Info	https://pipl.com/ http://www.peakyou.com/ http://com.lullar.com/ , http://whitepages.sg http://tineye.com
Doxing – IP Address Info	http://whatismyipaddress.com/ip-lookup

Summary

- Google Hacking – stealthy reconnaissance
- Google search – basic and advanced search operators
- Search strings with advanced operators - dorks
 - Private and sensitive corporate and personal information
 - Control of internet-connected devices
- Uses of Google Dorking
 - Information Disclosure, Vulnerability Assessment and Social Engineering
- Defences against Google Hacking
 - Strong authentication, proper configuration, good security policies, user education, robots.txt
- Doxing – reconnaissance on people and places to support social engineering
- **Next Lecture – Scanning and Enumeration**



QUESTIONS OR COMMENTS?